

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trung tâm Điều hành An ninh được đánh giá ở chỗ một cuộc xâm nhập thật có bị bắt kịp lúc hay không, thế nhưng khối lượng phải soi xét lại vượt xa những gì các chuyên viên trực ca đọc nổi. Các hướng đối phó hiện hành mỗi hướng chỉ giải quyết được một phần: luật chữ ký quyết định rất nhanh nhưng không diễn giải được ý đồ, nền tảng tương quan gom được bằng chứng nhưng vẫn trao cho con người nhiều ứng viên hơn mức họ xử lý xuể, còn kịch bản tự động chỉ chạy đáng tin trên đúng những tình huống đã có người lường trước. Phân động lại cho chuyên viên—dựng ngữ cảnh quanh một cảnh báo rồi phán đoán nó—đúng là phần không mở rộng quy mô được. Luận văn đề xuất SENTINEL, một kiến trúc an ninh nhận thức hai tầng vận hành cục bộ hoàn toàn (air-gapped), đặt quyết định rẽ đứng trước quyết định đắt để năng lực suy luận chỉ tiêu tồn ở nơi thật sự cần. Tầng 1 là bộ lọc tốc độ đường truyền—luật xác định, chấm bắt thường Welford và cổng LightGBM—giải quyết nhiều nền của luồng mà không phải gọi tới mô hình ngôn ngữ. Sự kiện sống sót mới tới Tầng 2, một tác tử có trạng thái vận hành mô hình lượng tử hoá đặt tại chỗ phía sau các rào chắn mật mã, với ngữ cảnh dựng từ chính nhật ký thô (dòng yêu cầu, tiêu đề, payload, thông kê luồng) và nén lại bằng kỹ thuật gom khuôn mẫu nhật ký dưới một ngân sách token tường minh. Tri thức an ninh là kho truy xuất gồm 433 mục kỹ thuật MITRE ATT&CK cùng các quy trình xử lý sự cố của NIST SP 800-61r2, lập chỉ mục vừa dạng véc-tơ dày cho tương đồng ngữ nghĩa vừa dạng chỉ mục thưa BM25 cho các định danh chính xác, hai bảng hạng hợp nhất bằng Hợp nhất Hạng Nghịch đảo; một phép kiểm ở đầu ra giữ lại chờ chuyên viên mọi kỹ thuật vắng mặt trong tập tài liệu truy xuất của chính lô đó. Đo trên các bộ dữ liệu xâm nhập chuẩn, Tầng 1 cùng Cổng Học máy gỡ tải 90,6% lưu lượng, kéo độ trễ toàn tuyến ở mức trung vị còn 0,88 ms so với 17.174,7 ms của đường LLM đơn tầng. Cơ chế đóng gói nonce phân định vô hiệu hoá tiêm nhiễm câu lệnh bằng cấu trúc chứ không bằng nhận dạng nội dung, kháng được toàn bộ 678 mẫu đối kháng mà lớp lọc tĩnh không hấp thụ được; chuỗi niêm phong HMAC-SHA256 phát hiện mọi kiểu giả mạo cốt lõi, bảo đảm tính toàn vẹn và khả năng phát hiện giả mạo của nhật ký kiểm toán, song do dùng khoá đối xứng thì không cấu thành chống chối bỏ theo nghĩa mật mã học.

Lời cảm ơn

Để hoàn thành công trình nghiên cứu này và đạt được học vị Thạc sĩ Kỹ thuật Phần mềm, tôi đã nhận được sự hỗ trợ, động viên và dìu dắt quý báu từ rất nhiều cá nhân và tập thể.

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và kính trọng sâu sắc nhất tới hai thầy hướng dẫn khoa học của tôi, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Với tri thức học thuật uyên bác, sự định hướng chiến lược chuẩn xác và tinh thần làm việc nghiêm túc, quý thầy đã luôn dành thời gian kiên nhẫn chỉ bảo, định hướng tư duy phản biện và truyền cảm hứng nghiên cứu cho tôi trong suốt chặng đường thực hiện luận văn. Những góp ý chuyên môn sắc bén của quý thầy không chỉ giúp tôi hoàn thiện công trình này mà còn là hành trang tri thức vô giá cho sự nghiệp nghiên cứu an toàn thông tin và trí tuệ nhân tạo của tôi sau này.

Tôi xin trân trọng gửi lời tri ân tới Ban Giám hiệu, Ban Lãnh đạo Viện Quản trị & Công nghệ FSB cùng toàn thể quý thầy cô Trường Đại học FPT đã truyền dạy nền tảng tri thức lý thuyết và thực tiễn vững chắc trong một môi trường nghiên cứu chuyên nghiệp, hiện đại. Tôi cũng xin chân thành cảm ơn Ban Lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia—sự tin tưởng, điều kiện thuận lợi về thời gian cùng những kinh nghiệm thực chiến phong phú từ đơn vị đã đem lại góc nhìn thực tiễn sâu sắc, áp dụng trực tiếp vào quá trình thiết kế, thực nghiệm và kiểm chứng hệ thống SENTINEL.

Cuối cùng, và cũng là niềm tự hào lớn lao nhất, tôi xin dành trọn lòng tri ân sâu sắc nhất tới gia đình thân yêu, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn vô bờ bến và nguồn động viên không ngừng nghỉ của vợ và con trong những tháng ngày tôi miệt mài với các đợt thực nghiệm kéo dài xuyên đêm chính là điểm tựa vững chắc nhất giúp tôi hoàn thành công trình này. Mặc dù đã rất cố gắng, luận văn khó tránh khỏi hạn chế; tôi rất mong nhận được sự chỉ dẫn và đóng góp quý báu từ quý thầy cô trong Hội đồng chấm luận văn cùng các đồng nghiệp.

Mục lục

Tóm tắt	i
Lời cảm ơn	ii
Danh sách hình vẽ	iv
Danh sách bảng	iv
Danh mục các từ viết tắt	vi
1 Giới thiệu	1
1.1 Bối cảnh và Động lực Nghiên cứu	1
1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp	2
1.3 Cấu trúc của Luận văn	4
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	5
2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức	5
2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1	5
2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2	6
2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký	7
2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu	8
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	10
3.1 Phương pháp Nghiên cứu	10
3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC	11
3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy	12
3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa	14
3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG	16
3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã	18
3.7 SOC Dashboard và Kiến trúc Triển khai Cục bộ	20
4 Thực nghiệm và Đánh giá	21
4.1 Môi trường Thực nghiệm	21
4.2 RQ1 — Xả tải và Kinh tế học Tầng lọc	22
4.3 RQ2 — Rào chắn An ninh AI và Toàn vẹn Pháp y	25
4.4 RQ3 — Suy luận Có trạng thái và Quy kết Kỹ thuật	28
5 Kết luận	34
Tài liệu tham khảo	1

Danh sách hình vẽ

Hình 1.	SENTINEL ở mức khối: hai tầng tách nhau theo chi phí, với một đường leo thang duy nhất nối giữa. (Nguồn: Tác giả)	11
Hình 2.	Tầng 1 phóng to. Chỉ nhánh ESCALATE đi tới Tầng 2; mọi phán quyết khác kết thúc tại đây, và đó chính là thứ Chương 4 tính là xả tải. (Nguồn: Tác giả)	13
Hình 3.	Đồ thị trạng thái tác tử Tầng 2, phản ánh đúng <code>src/agent/workflow.py</code> : đồ thị không chu trình, mọi đường đi đều kết thúc ở một hành động đã thực thi, một lần chuyển chuyên viên, hoặc kết thúc chu kỳ. (Nguồn: Tác giả)	15
Hình 4.	Truy xuất Dual-RAG và rào chắn neo bằng chứng. Phép kiểm nằm ở phía đầu ra: nó ràng buộc thứ mô hình được phép khẳng định, không phải thứ bộ truy xuất được phép trả về. (Nguồn: Tác giả) . .	17
Hình 5.	Đóng gói nonce ở biên đầu vào và chuỗi HMAC ở biên đầu ra. Điểm mù cắt đuôi được vẽ ra chứ không lược đi, vì nó là hệ quả của chính cấu trúc. (Nguồn: Tác giả)	19
Hình 6.	Cơ cấu xả tải trên hai luồng; tầng gánh chính đảo vai theo tỉ lệ tấn công nền. Sinh từ <code>offload_vs_baserate_{stream,demo}.json</code> . (Nguồn: Tác giả)	23
Hình 7.	Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ <code>latency_benchmark.json</code> . (Nguồn: Tác giả)	24
Hình 8.	Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhầm trên log lạnh. Sinh từ <code>robustness_results.json</code> và <code>adversarial_negative_results.json</code> . (Nguồn: Tác giả) . . .	27
Hình 9.	Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhạt cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhạt bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)	30
Hình 10.	Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ <code>tier2_decision_results.json</code> . (Nguồn: Tác giả)	31
Hình 11.	Trái: độ chính xác hành động theo cấu hình kèm khoảng tin cậy 95%; A và F chung mẫu số, B–E thì không. Phải: bốn trục trọng tài chấm, với độ chính xác ngữ cảnh là trục yếu. Sinh từ <code>ablation_action_scores.json</code> và <code>reasoning_eval_results.json</code> . (Nguồn: Tác giả)	33

Danh sách bảng

Bảng 1.	Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành	9
Bảng 2.	Cấu hình Thực nghiệm và Phân vai Tập Dữ liệu	22
Bảng 3.	Tỉ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau	22
Bảng 4.	Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng	25
Bảng 5.	Các lớp rào chắn, mẫu số phép đo và kết quả	26
Bảng 6.	Quy kết theo từng kỹ thuật trên lát 500 mẫu tầng payload, kèm trần truy xuất của cùng bộ truy vấn. Quy kết chấm trên cả 250 mẫu có nhãn; truy xuất chấm trên 243 mẫu mà Tầng 1 có leo thang, và ở mức kỹ thuật cha—hai mẫu số vì vậy lệch nhau và không thay thế cho nhau được.	29
Bảng 7.	Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên không so trực tiếp với A và F được. Sinh từ <code>ablation_action_scores.json</code>	32

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DAPT	Dynamic Advanced Persistent Threat (Tấn công APT động)
FAISS	Facebook AI Similarity Search (Cơ máy tìm kiếm tương đồng FAISS)
FPR	False Positive Rate (Tỷ lệ báo động giả)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất GGUF)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông điệp dựa trên hàm băm)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge (Khung tri thức chiến thuật và kỹ thuật tấn công MITRE)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOAR	Security Orchestration, Automation, and Response (Điều phối, tự động hóa và phản hồi an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)

Chương 1

Giới thiệu

Chương này xác lập bối cảnh nghiên cứu và bài toán trung tâm của SENTINEL—một kiến trúc nhận thức hai tầng tự động hoá quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC)—cùng mục tiêu, câu hỏi nghiên cứu, phạm vi và đóng góp của luận văn.

1.1 Bối cảnh và Động lực Nghiên cứu

Một Trung tâm Điều hành An ninh cỡ vừa hiện mỗi ngày nhận về hàng triệu sự kiện nhật ký [1], gần như toàn bộ chỉ ghi lại hoạt động bình thường. Vì cái giá của việc bỏ lọt một cuộc xâm nhập lớn hơn nhiều so với cái giá của việc xem xét một sự kiện vô hại, các hệ thống giám sát được đặt lệch hẳn về phía nhạy, và người vận hành cho biết chỉ một phần nhỏ trong số cảnh báo đến tay họ là đáng ra tay [2, 3]. Mỗi cảm biến lắp thêm đều làm số cảnh báo tăng lên trong khi số chuyên viên đủ sức đọc những cảnh báo ấy vẫn giữ nguyên, nên chỗ nghẽn của một SOC hiện đại không nằm ở khả năng phát hiện mà ở việc phân bổ sự chú ý khan hiếm của con người—thứ không nhân lên được bằng cách mua thêm máy chủ.

Ba lớp đối phó đứng giữa luồng dữ liệu và chuyên viên: tường lửa cùng hệ thống phát hiện xâm nhập đối sánh chữ ký tĩnh, nền tảng SIEM tương quan telemetry gom về một chỗ bằng luật viết tay, và nền tảng SOAR chạy kịch bản lập trình sẵn [4]. Mọi thứ ba lớp này không kết luận được đều rơi vào hàng đợi của chuyên viên, nơi công việc trở thành thủ công—lấy nhật ký thô ra, dừng lại xem địa chỉ nguồn đã làm gì quanh thời điểm bị gán cờ, đối chiếu địa chỉ đích với danh mục tài sản, và nhận diện hành vi giống kỹ thuật tấn công nào trước

khi quyết định chặn, bỏ qua hay chuyển tiếp. Mỗi bước đều là đọc và đối chiếu, mà đọc thì không song song hoá được.

Hai nhược điểm nảy sinh từ đây, và chúng là lý do tồn tại của luận văn này. Thứ nhất là thời gian: chuyên viên cần vài phút cho một cảnh báo trong khi luồng dữ liệu đến liên tục, nên hàng đợi có tốc độ đến vượt tốc độ phục vụ sẽ được giải quyết bằng cách bỏ dở chứ không phải làm xong. Thứ hai là ngữ cảnh: bằng chứng quyết định một vụ việc nằm rải rác trên nhiều bản ghi và vùi trong những trường phi cấu trúc, nên thứ cần đến không phải một khuôn mẫu để đối sánh mà là một phán đoán phải hình thành. Luật tính không diễn đạt nổi điều đó, còn chữ ký và kịch bản thì chỉ nhận ra những gì đã được mô tả. Mô hình Ngôn ngữ Lớn cung cấp đúng năng lực còn thiếu, với ba khoản chi phí mới: mỗi lần suy luận mất vài giây trong khi dữ liệu vẫn đến [5]; tầng suy luận trở thành mục tiêu, bởi một trường nhật ký có thể mang câu chữ do kẻ tấn công soạn để lái mô hình [6] và mọi kết luận phải chứng minh được là chưa bị sửa nếu muốn dùng làm chứng cứ; và nhật ký nội bộ thường không được phép rời khỏi tổ chức, nên mô hình phải chạy tại chỗ, trên phần cứng hữu hạn [7].

Quan sát nền tảng của nghiên cứu này là chênh lệch chi phí giữa hai loại phán quyết: luật thống kê quyết trong chưa tới một phần nghìn giây, mô hình ngôn ngữ quyết trong hàng giây. Khoảng cách bốn đến năm bậc độ lớn khiến việc đem mọi sự kiện qua tầng đắt nhất trở thành lãng phí có hệ thống. Mục tiêu của luận văn vì vậy là thiết kế, xây dựng và đánh giá thực nghiệm SENTINEL, một kiến trúc hai tầng dựng trên nguyên lý *đặt phán quyết rẻ trước phán quyết đắt*: một tầng lọc nhanh giải quyết dứt điểm phần lớn lưu lượng, và một tầng suy luận chỉ được gọi tới cho phần còn lại, phía sau các rào chắn bảo vệ cùng một vết kiểm toán niêm phong bằng mật mã, hoàn toàn trên hạ tầng cục bộ. Điều khiến đây là bài toán nghiên cứu chứ không chỉ là bài toán kỹ thuật nằm ở chỗ cả ba khoản chi phí ấy đều phải *đo được*, trên dữ liệu thật, bằng những thước đo không tự tăng bốc.

1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp

Mục tiêu tổng quát được cụ thể hoá thành ba nhiệm vụ nghiên cứu, mỗi nhiệm vụ đặt tương ứng một-một với một câu hỏi nghiên cứu và với đóng góp mà nó hướng tới. Chương 4 báo

cáo kết quả theo đúng ba đề mục ấy.

Nhiệm vụ thứ nhất là kinh tế học tầng lọc: một đường ống lọc hai chặng phi trạng thái vận hành ở tốc độ đường truyền, giải quyết phần lớn telemetry ngay tại tầng rẻ mà không tiêu tốn tài nguyên GPU. RQ1 đặt vấn đề: *Làm thế nào để thiết kế một kiến trúc phân tầng có khả năng xả tải tự động luồng dữ liệu an ninh ở tốc độ đường truyền nhằm giải quyết vấn đề “nút thắt cổ chai” về độ trễ và tiêu thụ tài nguyên của các Mô hình Ngôn ngữ Lớn?* Đóng góp hướng tới là định lượng nguyên lý đặt phán quyết rẻ trước phán quyết đắt, đồng thời chứng minh bằng số đo rằng tỉ lệ xả tải là hàm của tỉ lệ tấn công nền trong luồng chứ không phải hằng số của hệ—đặc tính chưa được các công trình liên quan phát biểu tường minh.

Nhiệm vụ thứ hai là an ninh của tầng suy luận: bảo vệ mô hình ngôn ngữ bằng cấu trúc thay vì bằng xác suất, và niêm phong hồ sơ pháp y sao cho mọi sửa đổi đều phát hiện được. RQ2 đặt vấn đề: *Phương pháp luận và cơ chế bảo mật nào có khả năng chống lại các rủi ro đối kháng (điển hình như tiêm nhiễm prompt qua nhật ký) nhằm bảo vệ luồng suy luận của AI, đồng thời bảo đảm tính toàn vẹn và khả năng phát hiện giả mạo của các vết chứng cứ pháp y?* Đóng góp hướng tới là cơ chế phòng thủ dựa trên Đóng gói Dữ liệu Phân định với Nonce mật mã ngẫu nhiên, mà tính chất cốt lõi là không phụ thuộc vào tỉ lệ chặn của bất kỳ bộ phân loại nào: nội dung trong vùng bọc được xử lý như văn bản thụ động bất kể nó nói gì, khác hẳn các bộ lọc ngữ nghĩa xác suất vốn suy giảm trước biến thể mới [8].

Nhiệm vụ thứ ba bao gồm suy luận, quy kết và tải người: một cỗ máy suy luận có trạng thái biết truy xuất tri thức chuyên ngành, trích dẫn bằng chứng đã dùng, và chuyển cho con người đúng những ca xứng đáng. RQ3 đặt vấn đề: *Làm thế nào để tích hợp năng lực suy luận có trạng thái và khả năng tra cứu tri thức chuyên ngành vào Tác tử AI nhằm tự động hóa quy trình phân tích, quy kết kỹ thuật tấn công và sinh ra các báo cáo pháp y minh bạch, qua đó giảm tải và phân loại chính xác phần công việc cần đến chuyên gia?* Đóng góp hướng tới là thay kịch bản SOAR cứng nhắc bằng một tác tử có trạng thái trên kho tri thức MITRE ATT&CK chuẩn STIX, kèm rào chắn neo-RAG tắt định buộc mọi mã kỹ thuật công bố phải hiện diện trong tài liệu truy xuất của chính lô đó—biến việc chống hư

cầu từ một kỳ vọng đặt vào mô hình thành một ràng buộc kiểm chứng được của kiến trúc.

Phạm vi được giới hạn như sau. Đối tượng nghiên cứu là chính kiến trúc SENTINEL: bộ lọc phi trạng thái Tầng 1, bộ đệm ngữ nghĩa Tầng 1.75, cỗ máy tác tử có trạng thái Tầng 2 chạy mô hình lượng tử hoá lưu trữ cục bộ, hệ truy xuất lai trên tri thức MITRE ATT&CK, cùng các cơ chế mật mã bảo vệ cả hai. Đánh giá dựa trên hai tập dữ liệu chính, CSE-CIC-IDS2018 [9] cho luồng giám sát mạng diện rộng và CSIC 2010 [10] cho tấn công HTTP Tầng 7; DAPT2020 [11] cho chuỗi đa giai đoạn và một tập zero-day tổng hợp chỉ đóng vai trò minh chứng khả thi, không tham gia bất kỳ tuyên bố đóng góp nào. Đánh giá đối kháng dùng 823 mẫu tách theo xuất xứ và không bao giờ gộp: 703 mẫu từ nguồn công bố (AdvBench [12], deepset [13], jackhhao [14]) làm mẫu số chính, 80 mẫu tác giả biên soạn, và 40 mẫu kiểm chéo. Hệ thống triển khai trên một máy trạm cách ly mạng; danh mục hành động tự động giới hạn ở chặn địa chỉ IP, ghi nhật ký hoặc chuyển chuyên gia.

1.3 Cấu trúc của Luận văn

Chương 2 hệ thống hoá cơ sở lý thuyết và tổng quan công trình liên quan nhằm xác định khoảng trống nghiên cứu. Chương 3 trình bày phương pháp nghiên cứu và thiết kế kỹ thuật của SENTINEL. Chương 4 trình bày kết quả định lượng, tổ chức theo đúng ba câu hỏi nghiên cứu ở trên, và Chương 5 kết luận.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này trình bày các nguyên lý lý thuyết nền tảng của luận văn—nút thắt vận hành SOC, cơ sở thống kê và học máy Tầng 1, kiến trúc tác tử và ngôn ngữ lớn Tầng 2, nguy cơ đối kháng cùng kiểm toán mật mã—và khảo sát các hệ thống hiện hành nhằm xác định khoảng trống nghiên cứu mà SENTINEL giải quyết.

2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức

Chương 1 đã nêu hệ quả vận hành; mục này nêu nguyên nhân kiến trúc của nó. Công tác giám sát thu thập nhật ký từ NGFW, IDS/IPS và EDR về hệ thống SIEM tập trung [1], ở khối lượng vượt quá khả năng phân tích thủ công [15]. Vấn đề không nằm ở việc gom về một chỗ mà ở chỗ mọi thiết bị nạp dữ liệu vào đó đều phán quyết bằng chữ ký tĩnh hoặc luật tắt định, nên đồn bầy duy nhất để giảm bỏ lọt là hạ ngưỡng, mà hạ ngưỡng thì sinh ra nhiều cảnh báo hơn chứ không tốt hơn [2]. SOAR tự động hoá phản hồi ở lớp trên, nhưng một playbook chỉ kích hoạt được với tình huống đã có người lường trước [4].

2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1

Một tầng chạy ở tốc độ đường truyền ràng buộc phương pháp trước khi chọn phương pháp: thứ dựng nên đường nền lưu lượng phải làm việc đó trong thời gian và bộ nhớ hằng số, vì một luồng vô hạn thì không đọc lại được và lịch sử theo từng khoá thì không giữ nổi. Điều đó loại bỏ mọi cách tính phương sai hai lượt và chỉ chấp nhận công thức truy hồi tăng dần của Welford [16], mang giá trị trung bình μ_k và tổng bình phương độ lệch S_k đi theo từng

quan sát một:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

Nhờ đó độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$ luôn sẵn sàng ở mọi bước, nên điểm Z được đánh giá trên một đường nền không bao giờ phải lưu lại—đường nền tự thích nghi khi lưu lượng dịch chuyển và không để lại cửa sổ lưu trữ nào cho kẻ tấn công chờ trôi qua. Mục 3.3 trình bày chi tiết các chặng phân loại và lưu đệm dựng trên nền này.

2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2

Việc chạy tầng suy luận tại chỗ chính là thứ làm nên chủ quyền dữ liệu và cũng là thứ khiến bộ nhớ thành ràng buộc siết chặt nhất. Tám tỉ tham số ở độ chính xác nửa chiếm khoảng 16 GB chỉ riêng cho trọng số, chưa kể kích hoạt và bộ đệm khoá-giá trị, tức đã vượt quá tám card 16 GB mà luận văn nhắm tới. Lượng tử hoá biểu diễn mỗi trọng số trên một lưới số nguyên thô hơn, đánh đổi một lượng trung thực số học có kiểm soát lấy mức giảm dung lượng tương ứng [17]: ở định dạng GGUF Q4_K_M phục vụ qua llama.cpp, Foundation-Sec-8B-Instruct [18], bản tinh chỉnh theo chỉ thị của mô hình nền Foundation-Sec-8B chuyên ngành an ninh mạng [19], chiếm 7–8 GB, chừa dư địa trên cùng tám card cho cửa sổ ngữ cảnh và chỉ mục truy xuất.

Tầng 2 điều phối suy luận bằng đồ thị trạng thái không chu trình LangGraph [20] tích hợp Bộ nhớ Đe dọa. Việc neo suy luận vào bằng chứng truy xuất được thay vì vào trí nhớ tham số [21] đặt ra một câu hỏi mà lĩnh vực an ninh trả lời khác với hỏi-đáp thông thường: truy vấn ở đây trộn lẫn xuôi tự do với những token buộc phải khớp theo mặt chữ, như mã kỹ thuật, số hiệu CVE hay giá trị cổng. Tìm kiếm véc-tơ dày [22] xử lý tốt về đầu và không đáng tin ở về sau, còn khớp từ khoá thưa [23] thì ngược lại; vì điểm số của hai bên nằm trên hai thang không so sánh được, chúng được hợp nhất theo thứ hạng—đúng tính chất mà

Reciprocal Rank Fusion khai thác [24]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

truy xuất trực tiếp từ 433 mục STIX MITRE ATT&CK và tài liệu NIST SP 800-61r2 làm căn cứ giải trình pháp y.

2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký

Tích hợp LLM phát sinh nguy cơ tiêm nhiễm câu lệnh qua nhật ký [6], khi kẻ tấn công nhúng câu lệnh vào chuỗi User-Agent hoặc tham số URI để thao túng suy luận của AI [8]. Vì nội dung nhật ký do chính kẻ tấn công soạn ra, mọi lớp phòng thủ dựa trên nhận dạng nội dung đều là cuộc đua bắt kịp với biến thể mới. Pandey và Bhujang [25] đo đúng mặt phơi nhiễm này trên một trợ lý phân tích SOC dùng LLM và cho thấy mỗi nguy không nằm ở chỗ trực giác tưởng: câu lệnh ghi đè thẳng thường không áp chế được cảnh báo phân loại nào dưới mọi chế độ phòng thủ, nhưng chính chiến lược đó vẫn đạt 15% tỉ lệ tiêm nhiễm thành công ở tác vụ tóm tắt khi đã lọc từ khoá. Cướp nhân cách áp chế được 68% nhật ký độc hại khi chưa phòng thủ và không giảm đơn điệu khi thêm lớp phòng thủ—nhắc lệnh có cấu trúc kéo xuống 15%, ràng buộc đầu ra lại để nó bật lên 33%—còn thao túng ngữ cảnh nhắm vào tác vụ tóm tắt thành công 96% khi không phòng thủ và 38% ngay cả khi đã ràng buộc đầu ra. Một bộ lọc tinh chỉnh cho nhóm dễ thấy vì thế vẫn để ngỏ đúng những nhóm hiệu quả—đó là căn cứ thực nghiệm cho việc phòng thủ véc-tơ này bằng cấu trúc. SENTINEL theo đó áp dụng Đóng gói Dữ liệu Phân định với Nonce ngẫu nhiên cô lập dữ liệu thô, kèm rào chắn tắt định ép đầu ra trong ba trạng thái (BLOCK_IP, LOG, AWAIT_HITL). Vết pháp y được niêm phong bằng chuỗi chữ ký HMAC-SHA256 [26] dưới một khoá bí mật cục bộ. Phạm vi bảo chứng phải phát biểu chính xác: vì HMAC dùng khoá đối xứng dùng chung, cơ chế này chứng minh được tính toàn vẹn và khả năng phát hiện giả mạo nhưng không cấu thành chống chối bỏ theo nghĩa mật mã học, vốn đòi hỏi chữ ký bất đối xứng—ranh giới được tôn trọng xuyên suốt luận văn.

2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu

Nghiên cứu ứng dụng trí tuệ nhân tạo trong vận hành an ninh mạng đã tiến triển qua ba nhóm giải pháp kiến trúc chính [27].

Nhóm thứ nhất, phòng thủ doanh nghiệp truyền thống, gồm các nền tảng SIEM như IBM QRadar và giải pháp SOAR như Palo Alto Cortex XSOAR [1, 4], tương quan sự kiện bằng tập luật tĩnh và chạy kịch bản định sẵn, nên thất bại khi gặp biến thể mà luật không lường trước. Cái giá của sự cứng nhắc đó đổ lên chuyên viên: qua phỏng vấn người vận hành SOC, AlAhmadi và cộng sự [3] ghi nhận chất lượng cảnh báo là than phiền lớn nhất, với mô tả rằng phần áp đảo cảnh báo không đáng để xử lý. Ưu thế của nhóm này là độ trễ rất thấp—đặc tính mà Tầng 1 của SENTINEL kế thừa thay vì loại bỏ.

Nhóm thứ hai, tác tử phân loại có tăng cường truy xuất, tiêu biểu là CyberRAG [28], điều phối các bộ phân loại tinh chỉnh theo từng họ tấn công phía sau một tác tử LLM và công bố độ chính xác trên 94% mỗi lớp trên các phép thử SQL injection, XSS và SSTI. Công trình này giải quyết chất lượng phân tích cho những sự kiện đã được chọn, không giải quyết câu hỏi đứng trước đó là sự kiện nào đáng được phân tích, nên không có tăng tốc độ đường truyền nào chặn nhịp đến của tầng suy luận.

Nhóm thứ ba, đa tác tử và chú trọng quản trị, gồm AutoBnB-RAG [29], LanG [30] và Policy-Guided Threat Hunting [31], không nên gộp vào một mô tả chung vì chúng khác nhau đúng ở chiều mà luận văn này đo. AutoBnB-RAG đánh giá phản ứng sự cố đa tác tử có truy xuất trong môi trường trò chơi bàn *Backdoors & Breaches*—nghiên cứu về phối hợp trong sự cố mô phỏng, không phải về tuyến xử lý sự kiện. LanG là công trình gần luận văn này nhất: cũng dựng trên LangGraph với chốt kiểm có người tham gia, công bố suy luận ≈ 21 ms và thời gian phát hiện trung bình phía máy 1,58 s, và—trái với bất kỳ khẳng định nào rằng các hệ này không có phòng thủ—đã có sẵn đường rào hai lớp kết hợp biểu thức chính quy với bộ phân loại ngữ nghĩa Llama Prompt Guard 2 đạt F1 98,1%. Policy-Guided Threat Hunting cũng đặt các chặng phi-LLM lên trước, dùng bộ tự mã hoá tái dựng và phân loại sơ bộ bằng học tăng cường sâu hai lớp trước khi LLM phân tích ngữ cảnh.

Vì vậy khoảng trống nghiên cứu hẹp hơn—và trung thực hơn—so với một sự thiếu vắng năng lực ở các công trình đi trước: phân tầng chi phí đã có ở Policy-Guided Threat Hunting, phòng thủ tiêm nhiễm đã có ở LanG, vận hành cục bộ đã có ở nhiều công trình. Thứ chưa kiến trúc đơn lẻ nào ráp lại được là tổ hợp—(1) giải quyết phần lớn lưu lượng ngay tại tầng thống kê/học máy với độ trễ dưới một mili-giây, và công bố tỉ lệ gỡ tải như một hàm của tỉ lệ tấn công chứ không phải một hằng số; (2) suy luận có trạng thái chạy cục bộ trên GPU 16 GB dưới một luật neo truy xuất, buộc giữ lại mọi kỹ thuật mà bằng chứng truy xuất được không chống đỡ; và (3) phòng thủ tiêm nhiễm có bảo chứng cấu trúc—suy ra từ vị trí đặt văn bản do kẻ tấn công soạn so với ranh giới chỉ thị, nên độc lập với câu chữ của payload, khác với một bộ phân loại xác suất dù điểm số cao đến đâu—cùng với niêm phong pháp y HMAC-SHA256. Bảng 1 đối chiếu chi tiết SENTINEL với các nhóm đại diện.

Bảng 1. Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành

Tiêu chí Đánh giá	SIEM / SOAR (QRadar, XSOAR)	Hệ tác tử LLM (CyberRAG, LanG, Policy-Guided)	Kiến trúc SENTINEL (Luận văn)
Kỹ thuật Cốt lõi	Tập luật tương quan tính, kịch bản Python/JS cứng	RAG tác tử, điều phối đa tác tử, phân loại sơ bộ bằng DRL	Bộ lọc Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Mục tiêu Vận hành	Gom nhật ký tập trung và phản hồi theo kịch bản	Tự động hóa điều tra sự cố bằng suy luận ngôn ngữ	Giải quyết lưu lượng tại tầng rẻ, dành tầng đắt cho ca cần suy luận
Phân tầng chi phí	Một tầng rẻ, không có suy luận	Có ở một số công trình (phân loại sơ bộ DRL), vắng ở số khác; gỡ tải không công bố theo tỉ lệ tấn công	Hai tầng: rẻ trước, đắt sau; gỡ tải công bố trên hai tỉ lệ tấn công
Chủ quyền Dữ liệu	Cục bộ nội bộ	Có công bố triển khai cục bộ; khung phần cứng không phải lúc nào cũng nêu	Air-gapped 100% trên GPU 16 GB
Chống Prompt Inj.	Không áp dụng	Bộ phân loại xác suất (LanG: regex + Prompt Guard 2, F1 98,1%)	Bảo chứng cấu trúc, độc lập với câu chữ payload
Kiểm toán Pháp y	Nhật ký văn bản tiêu chuẩn (để bị chỉnh sửa)	Có công bố nhật ký kiểm toán (LanG: mcp_audit.db); không niêm phong bằng mật mã	Chuỗi HMAC-SHA256 phát hiện giả mạo

Chương 3

Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày phương pháp nghiên cứu, sau đó là thiết kế và hiện thực SENTINEL: đường ống hai tầng, bộ lọc Tầng 1 và Cổng Học máy, cỗ máy tác tử Tầng 2 cùng Bộ nhớ Đề dọa, truy xuất Dual-RAG, các cơ chế an ninh đối kháng kèm niềm phong kiểm toán bằng mật mã, và kiến trúc triển khai cục bộ.

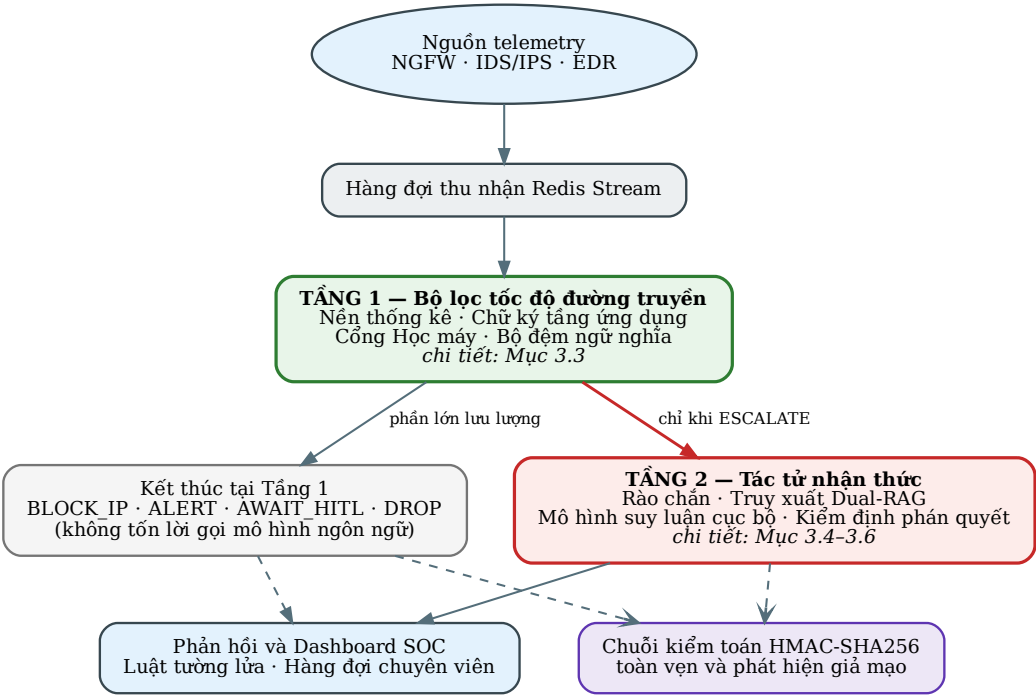
3.1 Phương pháp Nghiên cứu

Luận văn theo phương pháp Nghiên cứu Khoa học Thiết kế: đóng góp là một artefact, và artefact được đánh giá bằng số đo chứ không bằng lập luận. Ba trụ cột cấu thành nó. Trụ cột thống kê và học máy cung cấp khả năng lọc ở tốc độ đường truyền bằng thống kê trực tuyến Welford $\mathcal{O}(1)$ cho phát hiện bất thường theo điểm Z trượt, tiếp nối bằng phân loại LightGBM. Trụ cột logic tác tử cung cấp năng lực suy luận theo ngữ cảnh bằng đồ thị trạng thái LangGraph điều phối một mô hình ngôn ngữ đặt tại chỗ trên nền truy xuất lai FAISS/BM25/RRF. Trụ cột an ninh đối kháng cung cấp ranh giới phòng thủ. Hiệu lực được đánh giá trên năm chiều—chất lượng phân loại, hiệu năng xử lý, kháng đối kháng, độ mạch lạc của lời giải thích do một mô hình trọng tài độc lập chấm, và toàn vẹn kiểm toán—ánh xạ sang ba câu hỏi nghiên cứu ở Mục 1.2 và ba mục kết quả của Chương 4.

Ba nguyên tắc đo chi phối mọi con số báo cáo trong luận văn: mẫu số phải khớp câu hỏi, thước đo phải miễn nhiễm với tỉ lệ nền (dùng MCC và Balanced Accuracy thay cho Accuracy hay $F1$ nhị phân), và mọi tỉ lệ đều phải nêu kèm mẫu số cùng độ phủ phép đo. Mục 4.1 phân tích hệ quả của chúng ở đúng chỗ chúng phát huy tác dụng.

3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC

SENTINEL vận hành theo kiến trúc nhận thức hai tầng với nguyên lý cốt lõi là tách bạch công việc theo chi phí. Hình 1 trình bày kiến trúc ở mức khối: nhật ký thô từ các nguồn vành ngoài vào hàng đợi Redis Stream rồi chuyển cho Tầng 1—chặng thống kê và học máy phi trạng thái giải quyết phần lớn lưu lượng ở tốc độ đường truyền; chỉ những sự kiện gây nhân ESCALATE mới đi tiếp lên Tầng 2, nơi một tác tử mô hình ngôn ngữ có trạng thái suy luận sâu theo ngữ cảnh; và mọi phán quyết của cả hai tầng đều được niêm phong vào cùng một chuỗi kiểm toán. Mỗi khối được phóng to ở đúng mục mang tên nó, để người đọc chỉ gặp một mức trừu tượng tại một thời điểm.



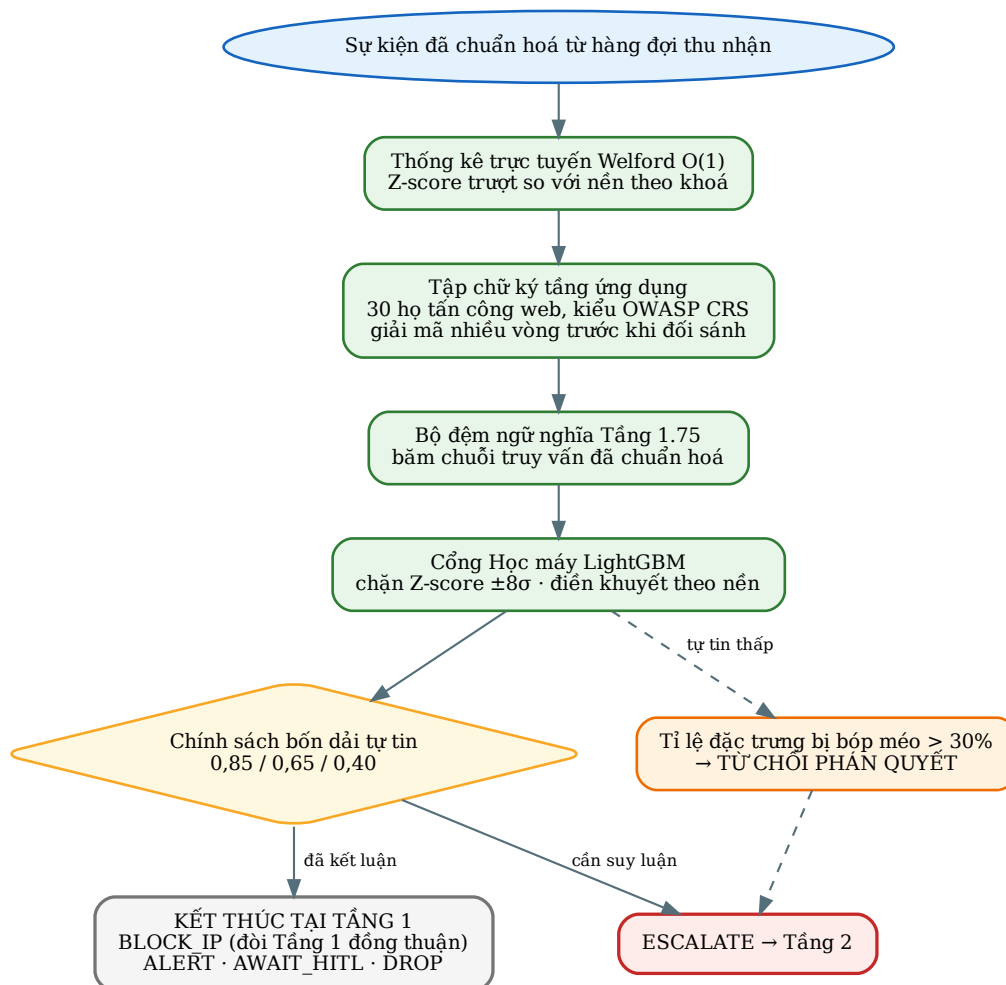
Hình 1. SENTINEL ở mức khối: hai tầng tách nhau theo chi phí, với một đường leo thang duy nhất nối giữa. (Nguồn: Tác giả)

Trong tập hành động của Tầng 1, chỉ ESCALATE đi tiếp lên Tầng 2, còn BLOCK_IP, ALERT, AWAIT_HITL và DROP đều kết thúc tại Tầng 1. Đây là căn cứ cho định nghĩa gỡ tải dừng ở Chương 4: một sự kiện được tính là đã gỡ tải khi nó không sinh ra lời gọi mô hình ngôn ngữ nào, bất kể phán quyết cuối là chặn hay cho qua.

Ở Tầng 2, tác tử LangGraph suy luận trên mô hình Foundation-Sec-8B-Instruct đặt tại chỗ, tích hợp trạng thái lịch sử từ Bộ nhớ Đe dọa và bằng chứng từ Dual-RAG, dưới một rào chắn tất định giới hạn trong ba trạng thái, với mọi bản ghi được niêm phong bằng chuỗi HMAC-SHA256. SENTINEL vì vậy đóng vai trò tầng trung gian nhận thức giữa bộ thu thập SIEM và các nền tảng tường lửa hay SOAR phía sau, hấp thụ nhiều luồng ở Tầng 1 và cung cấp lời biện giải có trích dẫn cho các sự kiện leo thang, với chủ quyền dữ liệu được bảo đảm nhờ vận hành cách ly mạng trên một GPU 16 GB VRAM duy nhất.

3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy

Tầng 1 là lớp vành ngoài phi trạng thái, kết hợp bộ lọc đường nền Welford $\mathcal{O}(1)$ (Công thức 2.1) với Cổng Học máy LightGBM nhằm bảo đảm độ trễ mili-giây trước mọi lời gọi GPU. Hình 2 phóng to khối tương ứng.



Hình 2. Tầng 1 phóng to. Chỉ nhánh ESCALATE đi tới Tầng 2; mọi phán quyết khác kết thúc tại đây, và đó chính là thứ Chương 4 tính là xả tải. (Nguồn: Tác giả)

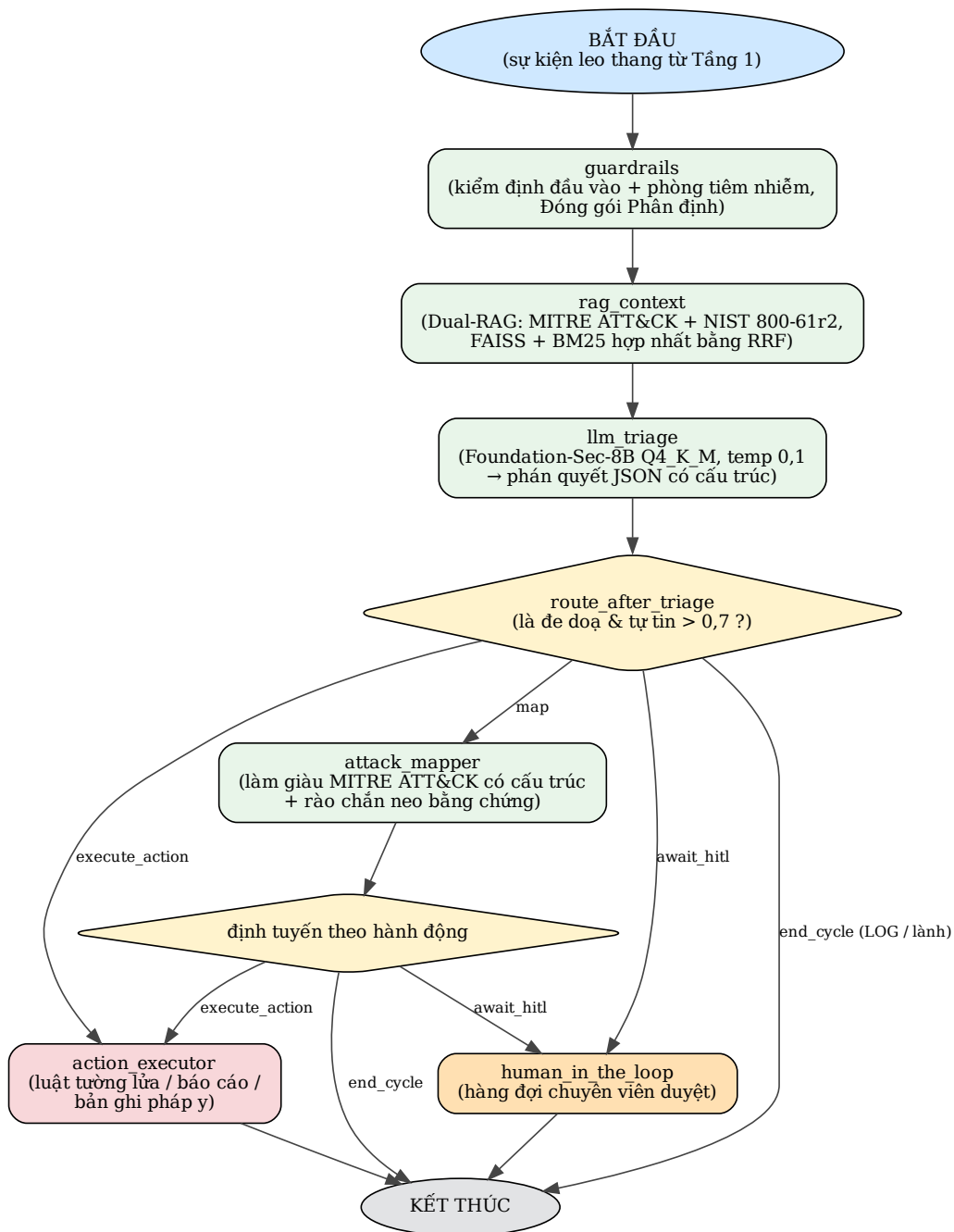
Bộ lọc thống kê tính $Z = (x - \mu) / \sigma$ theo thời gian thực trên các đặc trưng lưu lượng—tần suất gói tin, dung lượng luồng, thời lượng kết nối—with μ và σ cập nhật theo công thức truy hồi ở Mục 2.2 mà không lưu lịch sử thô [16]; lưu lượng tuân theo đường nền bị loại ngay. Bên cạnh đó, Tầng 1 vận hành bộ chữ ký tầng ứng dụng phủ 30 họ tấn công web, chuẩn hoá theo lỗi OWASP CRS để payload nguy trang bằng mã hoá vẫn khớp được. Để tập chữ ký này không chỉ là lời tự khai, 23 trong 30 họ ánh xạ sang tệp luật OWASP CRS 3.3 (11 tệp khác nhau) và tập chữ ký phủ đủ 10 hạng mục OWASP Top 10:2021; 7 họ còn lại là hành vi tầng endpoint và mạng như ransomware, đào tiền mã hoá và đánh cắp thông tin xác thực, vốn nằm ngoài phạm vi một bộ luật viết cho giao dịch HTTP. Với hành vi lặp lại theo

khối lượng, Bộ đệm Ngũ nghĩa Tầng 1.75 băm chuỗi truy vấn đã chuẩn hoá trong RAM và tái dùng phán quyết đã có.

Tiếp theo là mô hình Cây Quyết định Tăng cường Gradient LightGBM, đánh giá tương tác đặc trưng phi tuyến theo lối tăng trưởng theo lá, huấn luyện trên 949.535 mẫu NetFlow (664.674 huấn luyện, 189.907 giữ lại). Để vô hiệu hoá né tránh, Cổng cắt điểm Z của đặc trưng trong khoảng $\pm 8\sigma$ và bù giá trị thiếu bằng trung bình đường nền; nếu tỉ lệ đặc trưng bị bóp méo vượt 30%, Cổng bỏ phiếu trắng và leo thang thay vì trả lời tự tin mà sai, bởi một phán quyết sai đầy tự tin khiến hệ tự hành động mà không ai soát lại. Phán quyết của Cổng ánh xạ sang hành động qua chính sách tự tin bốn dải thống nhất (0,85 / 0,65 / 0,40 cho BLOCK_IP / ESCALATE / ALERT / LOG), để độ tự tin *điều khiển* hành động chứ không chỉ đi kèm nó; phần tự động chặn được cô lập ở dải cao nhất và còn đòi hỏi luật Tầng 1 đồng thuận.

3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đa dạng

Tầng 2 vận hành mô hình Foundation-Sec-8B-Instruct [18] lượng tử hoá theo cách đã trình bày ở Mục 2.3, phục vụ bằng llama.cpp biên dịch CUDA trên một GPU 16 GB VRAM. Hình 3 phóng to khối Tầng 2.



Hình 3. Đồ thị trạng thái tác tử Tầng 2, phản ánh đúng src/agent/workflow.py: đồ thị không chu trình, mọi đường đi đều kết thúc ở một hành động đã thực thi, một lần chuyển chuyên viên, hoặc kết thúc chu kỳ. (Nguồn: Tác giả)

Một đồ thị trạng thái LangGraph [20] điều phối năm nút: soát rào chắn, bồi đắp ngữ cảnh (rag_context), phân loại (llm_triage), ánh xạ kỹ thuật (attack_mapper), và thực thi hành động hoặc chuyển human_in_loop. Ánh xạ kỹ thuật đòi hỏi xác nhận tường minh

từ tri thức chuyên ngành; không có khớp rõ ràng thì đồ thị chuyển sang chuyên viên (AWAIT_HITL) thay vì phát ra một hành động phỏng đoán. Nhánh đó là đầu ra có chủ ý chứ không phải thất bại: hệ phân loại phân việc cần người chứ không loại bỏ con người. Tại `llm_triage`, hệ bóc sạch mọi trường phân loại nội bộ khỏi prompt—điều kiện tiên quyết cho tính hợp lệ của mọi phép đo ở Chương 4, vì một nhãn đáp án lọt vào ngữ cảnh sẽ để mô hình chép lại đáp án thay vì suy luận ra nó.

Hai cơ chế giới hạn thứ được phép đi vào chu trình đó. Các sự kiện lặp lại bị gom bởi Drain—khai phá khuôn mẫu nhật ký trực tuyến [32]—nhờ đó một đợt bùng nổ một nghìn dòng gần trùng tổn của cửa sổ ngữ cảnh xấp xỉ chi phí của một dòng. Tiếp đó, bộ giám sát ngân sách token ước lượng kích thước đầu vào trước mỗi lần gọi và ghi lại lượng thật sau đó, khiến việc tiến sát trần ngữ cảnh là điều kiện quan sát được chứ không phải một lần cắt cụt âm thầm; Mục 4.3 báo cáo kết quả của cặp cơ chế này trước một đầu vào cố ý làm quá khổ.

Để liên kết hành vi rải rác theo thời gian, Tầng 2 duy trì Bộ nhớ Đe dọa trên cơ sở dữ liệu SQLite tối ưu chỉ mục dùng rollback-journal thay cho WAL, tránh xung đột khoá tệp cross-UID trong Docker, theo dõi uy tín IP, thực thể nội bộ, chỉ báo rủi ro và sự kiện đe dọa. Điểm uy tín S suy giảm theo quãng im lặng t :

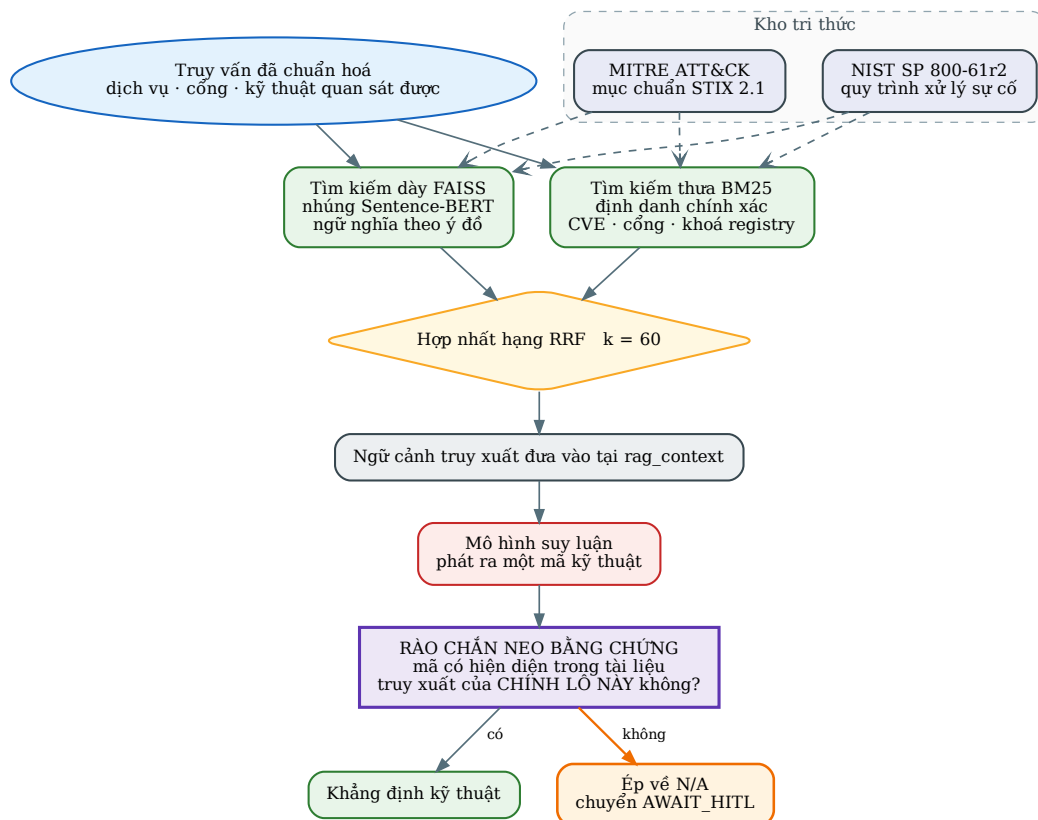
$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.1)$$

trong đó λ là tốc độ suy giảm. Khi chạm ngưỡng tối đa ($S = 100$), Tầng 1 áp dụng chặn-ngay-khi-thấy mà không kích hoạt lại Tầng 2, khép một vòng phản hồi biên chi phí suy luận một lần thành phán quyết tái sử dụng được. Địa chỉ hạ tầng nội bộ nằm trong danh sách trắng, tránh tự gây từ chối dịch vụ.

3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG

Để hạn chế hư cấu và neo phán quyết an ninh vào bằng chứng, Tầng 2 truy xuất trên 433 mục MITRE ATT&CK cấu trúc STIX 2.1 [33] và tài liệu hướng dẫn NIST SP 800-

61r2 [34]. Hai cơ chế chạy song song: tìm kiếm ngữ nghĩa dày bằng FAISS [22] với mô hình nhúng Sentence-BERT [35], giúp tìm ra kỹ thuật cùng ý đồ dù khác cách diễn đạt, và khớp từ khoá thưa bằng BM25 [23], bảo đảm truy xuất chính xác các định danh như mã CVE, khoá registry hay cổng dịch vụ. Ứng viên được hợp nhất bằng RRF (Công thức 2.2) với $k = 60$ rồi đưa vào prompt tại rag_context. Hình 4 thể hiện đường truy xuất cùng phép kiểm neo áp lên đầu ra của mô hình.



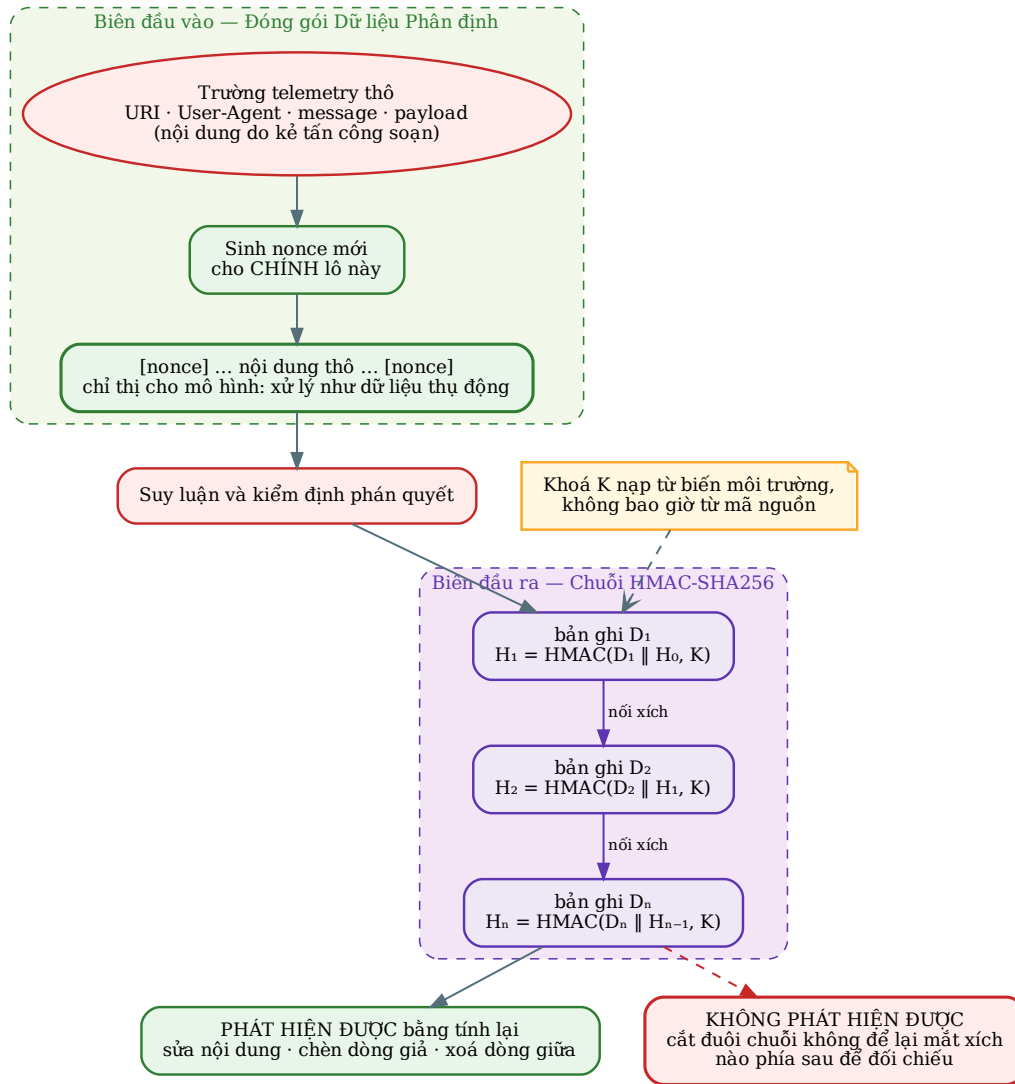
Hình 4. Truy xuất Dual-RAG và rào chắn neo bằng chứng. Phép kiểm nằm ở phía đầu ra: nó ràng buộc thứ mô hình được phép khẳng định, không phải thứ bộ truy xuất được phép trả về. (Nguồn: Tác giả)

Bản thân truy xuất cũng là một ranh giới tin cậy, vì một mục bị đầu độc sẽ được đọc như nguồn có thẩm quyền. Vì vậy một bộ khử độc RAG chuẩn hoá Unicode, bóc thẻ đánh dấu và vô hiệu hoá các cấu trúc mệnh lệnh trong mọi đoạn truy xuất được. Khó khăn nằm ở chỗ văn xuôi an ninh hợp lệ vốn ở thể mệnh lệnh—các bản khuyến cáo bảo người đọc hãy chặn, hãy tắt, hãy cô lập—nên một bộ lọc quá tay sẽ âm thầm làm hỏng chính kho tri thức

nó bảo vệ; Mục 4.3 báo cáo tỉ lệ vô hiệu hoá oan trên toàn bộ kho. Sau đó hệ áp dụng rào chắn neo bằng chứng: mọi mã kỹ thuật mô hình phát ra đều được đối chiếu ngược với tài liệu truy xuất của chính lô đó, mã không hiện diện bị ép về N/A và chuyển AWAIT_HITL. Đây là ràng buộc kiểm chứng được của kiến trúc, không phải sự phụ thuộc vào mức độ hay hư cấu của một mô hình cụ thể.

3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã

Tiêm nhiễm câu lệnh qua nhật ký [6] chèn câu lệnh điều khiển vào các trường nhật ký thô—User-Agent, tham số URI, nội dung Syslog—nhằm chiếm quyền điều khiển hành vi mô hình. SENTINEL áp dụng Đóng gói Dữ liệu Phân định với nonce mật mã sinh mới theo từng lô [8], bọc nhật ký thô trong cặp phân định mang nonce để mô hình xử lý nội dung như dữ liệu thụ động. Sinh theo từng lô là bắt buộc: một dấu phân định bất biến có thể bị suy ra từ mã nguồn hoặc quan sát lặp lại, sau đó kẻ tấn công tự đóng vùng bọc để thoát ra. Ba bộ thẩm định tất định canh giữ các ranh giới mô hình có thể chạm tới. Bộ thẩm định dữ liệu loại bỏ nhật ký dị dạng trước khi nó được đóng khung thành prompt. Bộ thẩm định quyết định ép tuân thủ lược đồ Pydantic (LLMDecision), ràng buộc hành động trong tập giá trị cho phép và từ chối lệnh chặn nhắm vào dải địa chỉ nội bộ hoặc dành riêng, lùi về AWAIT_HITL khi lỗi định dạng không cứu được. Bộ thẩm định phản hồi áp cùng thể trận zero-trust lên những luật hệ tự đề xuất, để một phán quyết bị thao túng không cài được luật vĩnh viễn vào Tầng 1.



Hình 5. Đóng gói nonce ở biên đầu vào và chuỗi HMAC ở biên đầu ra. Điểm mù cắt đuôi được vẽ ra chứ không lược đi, vì nó là hệ quả của chính cấu trúc. (Nguồn: Tác giả)

Về kiểm toán, mỗi bản ghi phán quyết thứ i được liên kết chuỗi bằng HMAC-SHA256 [26]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.2)$$

trong đó D_i là bản ghi hiện tại, H_{i-1} là hash liên trước, và K là khoá bí mật cục bộ nạp từ môi trường thay vì viết cứng trong mã, bởi một khoá lộ trong mã nguồn cho phép giả mạo lại toàn bộ chuỗi. Mọi sửa đổi hay xoá bỏ đều phá vỡ tính liên tục và bị phát hiện ngay, bảo đảm tính toàn vẹn và khả năng phát hiện giả mạo, song không phải chống chối bỏ—vì lý

do khoá đối xứng đã nêu ở Mục 2.4.

3.7 SOC Dashboard và Kiến trúc Triển khai Cục bộ

Bảng điều khiển SOC Analyst Dashboard dựng trên Streamlit, kết nối Redis Stream và Bộ nhớ Đe dọa để cung cấp góc nhìn thời gian thực: phễu gõ tải theo tầng, dòng thời gian chuỗi tấn công đa giai đoạn, tình trạng toàn vẹn chuỗi HMAC, và bảng kiểm duyệt HITL. Nhịp nạp dữ liệu được điều tiết bằng backpressure đo theo độ trễ consumer-group chứ không theo độ dài stream; vì subscriber tiêu thụ bằng XREADGROUP và XACK, hai thao tác đều không xoá entry, nên độ dài stream luôn dính sát ngưỡng trần dù consumer xử lý nhanh đến đâu, và tự hãm theo nó sẽ treo producer trước một hàng đợi thực ra đã trống.

Toàn bộ dịch vụ đóng gói bằng Docker Compose, llama.cpp biên dịch kèm CUDA cho RTX 4060 Ti, còn threat_memory.db và chỉ mục FAISS gắn trên ổ đĩa bền vững để điểm uy tín cùng bản ghi kiểm toán sống sót qua các lần khởi động lại. Triển khai tuân thủ nguyên tắc Zero Trust [7]: chuỗi mật khẩu trong REDIS_URL được che trước khi ghi nhật ký.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày kết quả định lượng, tổ chức theo đúng ba câu hỏi nghiên cứu ở Chương 1. Mọi tỉ lệ đều nêu kèm mẫu số đã đo trên đó.

4.1 Môi trường Thực nghiệm

Hệ thống chạy trên một máy chủ cách ly mạng, toàn bộ vi dịch vụ đóng gói bằng Docker Compose. Theo Mục 3.1, chỉ số phụ thuộc phân bố lưu lượng (tỉ lệ xả tải) đo trên luồng thực, còn chất lượng phân loại đo trên tập cân bằng lớp; đo xả tải trên tập ép cân bằng 50/50 sẽ cho con số thấp giả tạo, vì tập đó không phải phân bố mà hệ gặp. Bảng 2 phân vai từng tập. Hai giao ước áp cho mọi lượt đo: luật động bị đóng băng khi đo, và 50 mẫu do tác giả biên soạn trong `ground_truth.json` bị loại khỏi mọi tỉ lệ, vì chúng chiếm 16,7% tập chấm quy kết và toàn bộ mang cùng một đáp án.

Bảng 2. Cấu hình Thử nghiệm và Phân vai Tập Dữ liệu

Thành phần	Thông số	Vai trò trong phép đo
Vi xử lý (CPU)	Intel Core i7	Bộ lọc Welford và luồng Redis
Bộ nhớ RAM	32 GB DDR5	Semantic Cache và chỉ mục FAISS
Card đồ họa (GPU)	RTX 4060 Ti 16 GB	11ama.cpp CUDA, Foundation-Sec-8B-Instruct [18]
Ảo hóa	Docker Compose	Môi trường air-gapped, tái lập được
datatest.json	4.240 → 4.236 khi chấm, 51,8% tấn công	Chất lượng phân loại Cổng ML. Trích từ CSE-CIC-IDS2018 [9], CSIC 2010 [10] và DAPT 2020 [11]. Không dùng cho tỉ lệ xả tải
ground_truth.json	1.750 mẫu → 1.700 khi chấm	Ablation, chất lượng lập luận. 50 mẫu tác giả biên soạn bị loại khỏi mọi tỉ lệ
build_stream()	25.799 (150 khởi động + 25.649 chấm), 31,6% tấn công	Tỉ lệ xả tải, toàn tuyến
Luồng dạng SOC	99.717 sự kiện, 9,8% tấn công	Tỉ lệ xả tải ở base-rate gần thực tế
Tập đối kháng	823 = 703 công bố + 80 tự soạn + 40 kiểm chéo	AdvBench [12], deepset [13] và một tập jailbreak [14] có nguồn gốc từ nghiên cứu thực địa của Shen và cộng sự [36]. Ba xuất xứ chấm tách bạch, không bao giờ gộp

4.2 RQ1 — Xả tải và Kinh tế học Tầng lọc

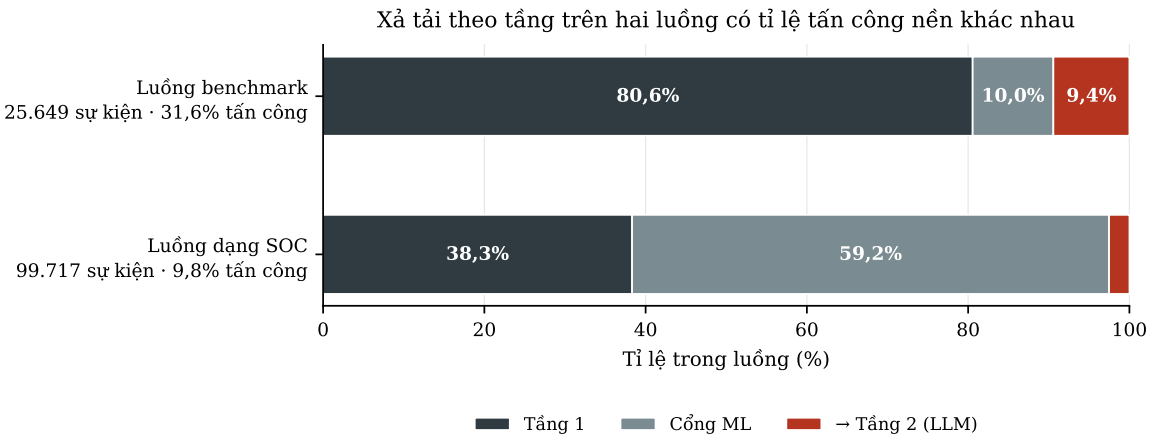
Một sự kiện được tính là đã gỡ tải khi nó không phát sinh lời gọi mô hình ngôn ngữ (Mục 3.2); cách đếm chỉ tính DROP sẽ bỏ sót BLOCK_IP, ALERT và AWAIT_HITL, vốn cũng không tồn một token nào.

Bảng 3. Tỉ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau

Tầng giải quyết	Luồng benchmark 25.649 sk		Luồng dạng SOC 99.717 sk	
	Số sự kiện	Tỉ lệ	Số sự kiện	Tỉ lệ
Tầng 1 (luật + Welford + chữ ký)	20.663	80,6%	38.207	38,3%
Cổng Học máy (LightGBM 4 dải)	2.568	10,0%	58.992	59,2%
Cộng dồn — không chạm LLM	23.231	90,6%	97.199	97,5%
Còn lại → Tầng 2 (LLM)	2.418	9,4%	2.518	2,5%
Tỉ lệ tấn công của luồng	31,6%		9,8%	

Bảng 3 mang chính đóng góp: tỉ lệ gỡ tải là hàm của tỉ lệ tấn công nền trong luồng, không phải hằng số của hệ. Trong cùng một luồng, nó phân tách tuyến tính thành gỡ tải(p) = $(1 - p) \cdot \text{gỡ tải}_{\text{lãnh}} + p \cdot \text{gỡ tải}_{\text{tấn công}}$. Hai hệ số theo nhãn của luồng chuẩn, 92,35% với ca

lành và 86,72% với ca tần công, tái lập đúng con số đo được 90,6%; trên luồng dạng SOC, 97,88% và 93,77% tái lập 97,5%. Vì các hệ số khác nhau giữa hai luồng, quan hệ này cho phép ngoại suy sang một tỉ lệ nền khác trong cùng một luồng chứ không cho phép bê từ luồng này sang luồng kia—và 90,6% vì thế không phải cái trần mà là hệ quả của một luồng thử nạp tỉ lệ tần công cao hơn ba lần mức thực tế. Tầng gánh chính cũng đảo vai: Tầng 1 giải quyết 80,6% ở luồng benchmark, còn Cổng ML mới là tầng gánh chính với 59,2% ở luồng lành áp đảo, tức hai tầng bù trừ cho nhau chứ không chồng lấn.



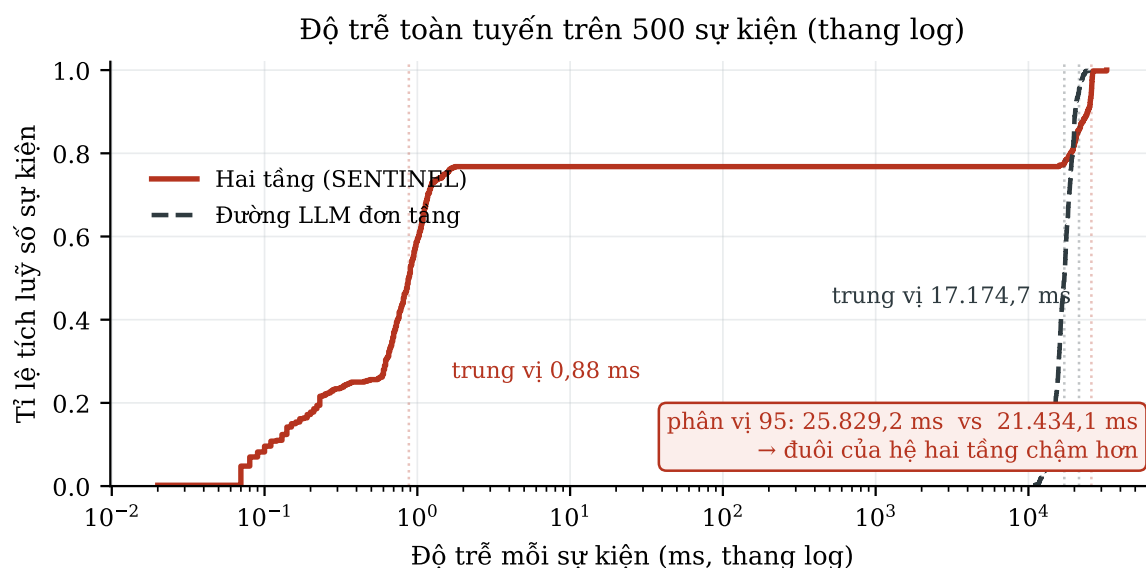
Hình 6. Cơ cấu xả tải trên hai luồng; tầng gánh chính đảo vai theo tỉ lệ tần công nền. Sinh từ `offload_vs_baserate_{stream,demo}.json`. (Nguồn: Tác giả)

Cổng Học máy xử lý một véc-tơ đặc trưng trong 0,287 ms (3.452 sự kiện/giây) và bộ đệm Tầng 1.75 trúng 81,3% trong 1.500 truy vấn với mức tăng tốc 8,9×. Một con số chất lượng phải nằm cạnh những số trên, vì tỉ lệ gỡ tải 90,6% cũng đọc xuôi tai y như cho qua gần hết nếu phần đã gỡ tải bị phán quyết sai: trên `datatest.json`, Cổng đạt MCC 0,667 và Balanced Accuracy 0,833—dùng MCC thay Accuracy, bởi trả lời lành ở mọi nơi đã đạt 90,2% Accuracy trên luồng dạng SOC. Mẫu số đi kèm: trong 4.236 sự kiện, Cổng chỉ phán quyết 2.534, vì 1.586 sự kiện thiếu đặc trưng payload và 116 ca bỏ phiếu trắng. Phần 962 lệnh tự động chặn đạt Precision 100% với không một dương tính giả, và đó là điều kiện bắt buộc chứ không phải thành tích: gỡ tải mà chặn nhầm khách hàng thật là tổn thất, không phải hiệu quả.

Thu 598 luật từ các phán quyết chặn của Cổng làm tỉ lệ leo thang giảm từ 20,28% xuống 17,98%, tức giảm tương đối 11,35%, trong khi chất lượng phát hiện tăng chứ không giảm. Hai giới hạn giữ cho tuyên bố đúng tầm: giá trị MCC tuyệt đối vẫn thấp (0,071 → 0,109),

nên thực nghiệm chứng minh cơ chế vận hành được chứ không chứng minh Tầng 1 mạnh; và mô phỏng lạc quan, vì kẻ tấn công không đổi địa chỉ nguồn còn chuyên viên duyệt mọi luật đề xuất.

Trên 500 sự kiện lấy mẫu bước nhảy từ `build_stream()`, độ trễ trung bình giảm từ 17.187,9 ms xuống 5.286,7 ms ($-69,2\%$, kiểm định Mann-Whitney U $p \approx 9 \times 10^{-57}$), còn trung vị từ 17.174,7 ms xuống 0,88 ms—khoảng 19.500 lần, bởi sự kiện điển hình không bao giờ chạm tới mô hình. Hai kết quả bất lợi phải nêu. Phân vị thứ 95 xấu hơn, 25.829 ms so với 21.434 ms, và xấu vì cấu trúc: một sự kiện có leo thang thì đã trả chi phí Tầng 1 và Cổng trước khi trả chi phí mô hình, nên lợi ích nằm ở trung vị chứ không ở phần đuôi. Và tỉ lệ gỡ tải của chính lượt đo này chỉ đạt 76,8%, không phải 90,6% như Bảng 3, vì 500 mẫu lấy theo bước nhảy không tích lũy đủ tiền sử theo địa chỉ để danh sách chặn phát huy tác dụng. Phần tài nguyên báo bằng số lời gọi đã tránh (97.199 trên 99.717 sự kiện) chứ không bằng tỉ lệ giảm VRAM, bởi không có phép đo VRAM nào được thực hiện.



Hình 7. Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ `latency_benchmark.json`. (Nguồn: Tác giả)

Bốn cấu hình đối chứng được đo trên cùng một mẫu con 150 sự kiện phân tầng, thay vì chép số headline từ công trình khác—phép so đó bắc qua hai tập dữ liệu và hai định nghĩa chỉ số khác nhau.

Đường tắt định chạy nhanh hơn $20.531\times$ so với đẩy mọi sự kiện lên mô hình. Chữ ký tĩnh

Bảng 4. Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng

Cấu hình đối chứng	Thông lượng
H1 — Chữ ký tĩnh, 30 họ WAF	11.129 sk/s
SENTINEL — Tầng 1 + Cổng ML	3.860 sk/s
H2 — LightGBM đơn tầng, ngưỡng phẳng	2.162 sk/s
H3 — LLM đơn tầng (cùng dữ liệu, mô hình và prompt)	0,19 sk/s

còn nhanh hơn nữa, khoảng ba lần SENTINEL, đúng như dự kiến vì chúng không thực hiện phép suy luận nào. Chính thứ tự này là luận điểm kiến trúc gói trong một dòng: mỗi tầng tốn đúng phần chi phí của nó, và câu hỏi thiết kế là giải quyết được bao nhiêu lưu lượng trước khi chạm tầng đất. Hai con số trong bảng không được cộng gộp, vì mức 0,19 sk/s đưa mỗi sự kiện qua toàn bộ tác tử Tầng 2 còn mốc 17.187,9 ms là một lời gọi mô hình trần, không trần token. Khi thử tải dồn trên luồng 99.717 sự kiện, backpressure theo độ trễ consumer-group giữ RAM và VRAM ổn định.

Ngưỡng chặn nằm trên một vùng phẳng—0,70 tới 0,85 cho chất lượng tổng hợp trùng khít, chỉ từ 0,90 trở lên độ bao phủ mới tụt—nên chọn 0,85 mua được biên an toàn rộng nhất cho việc tự động chặn mà không mất gì đo được, và độ chính xác của phần tự chặn giữ 1,00 trên mọi cấu hình đã quét. Với các bất thường tổng hợp tiêm từ 2σ tới 100σ trên bảy đặc trưng luồng, mọi phép thử ở mọi biên độ đều được leo thang nên không có gì lọt qua trong im lặng; nhưng phần nhận biết thống kê thì chững lại, tăng từ 19,52% ở 2σ lên 42,86% ở 4σ rồi chỉ đạt 54,29% ở 100σ . Vượt quá khoảng bốn độ lệch chuẩn, giới hạn nằm ở tập đặc trưng chứ không ở ngưỡng, nên hành vi mới lạ tới được Tầng 2 nhờ leo thang chứ không nhờ nhận dạng—kiểu thất bại đúng đắn, nhưng không phải một tuyên bố về năng lực phát hiện.

4.3 RQ2 — Rào chắn An ninh AI và Toàn vẹn Pháp y

RQ2 nêu tiềm nhiệm qua nền nhật ký là rủi ro *điển hình* chứ không phải toàn bộ phạm vi, nên hai mặt tấn công khác hẳn nhau về cấu trúc đều được đánh giá: tấn công qua ngôn ngữ, nơi kháng được nghĩa là chỉ thị nhúng không làm đổi hành động của tác tử, và tấn công

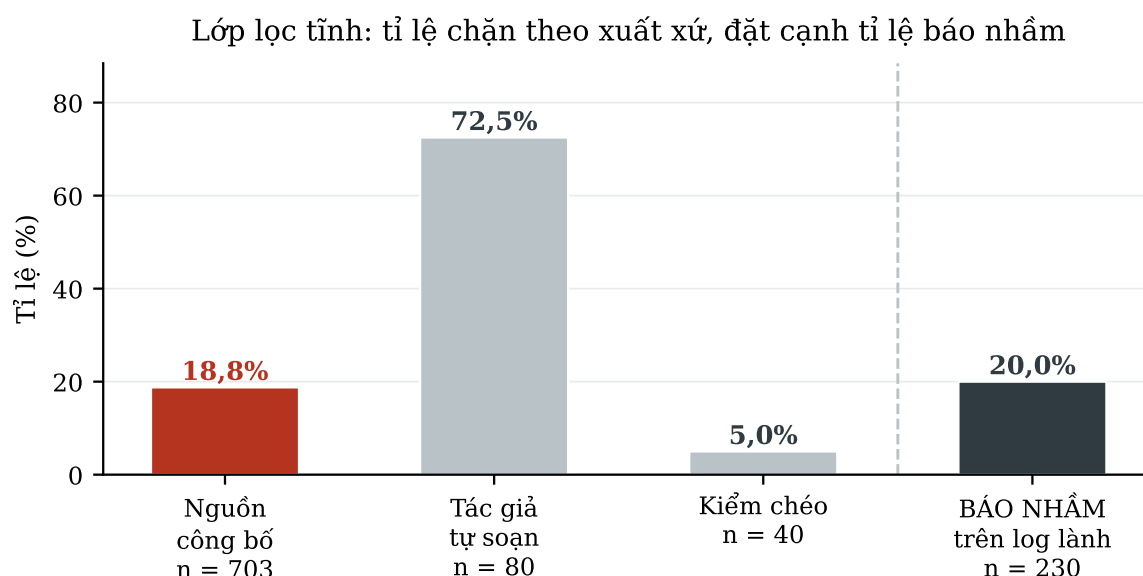
qua không gian đặc trưng, nơi kháng được nghĩa là mẫu bị bóp méo vẫn không bị lật thành lảnh. Ba giao ước làm cho các tỉ lệ đọc được. Phán quyết của lớp tĩnh là phép HOẶC của ba bộ dò ghi nhận riêng, để khi hỏng thì định vị được. Đối chứng âm trên 230 nhật ký lảnh là bắt buộc, bởi một lớp gấn cở mọi thứ cũng đạt chặn 100%. Và mẫu từ nguồn công bố không bao giờ gộp với mẫu do tác giả biên soạn.

Bảng 5. Các lớp rào chắn, mẫu số phép đo và kết quả

Lớp rào chắn	Mẫu số	Kết quả
<i>Tầng 1 — tấn công qua ngôn ngữ</i>		
Lớp lọc tĩnh, nguồn công bố	703 mẫu	132 → 18,8%
theo bộ dò: khớp mẫu / mã hoá / phân định	703	114 / 29 / 0
Lớp lọc tĩnh, mẫu tác giả biên soạn	80 mẫu	58 → 72,5%
Lớp lọc tĩnh, tập kiểm chéo	40 mẫu	2 → 5,0%
Lớp lọc tĩnh — báo nhằm trên nhật ký lảnh	230 nhật ký lảnh	46 → 20,0%
trong đó: lớp nhận dạng mã hoá	46/46	toàn bộ
<i>Tầng 1 — tấn công qua không gian đặc trưng</i>		
Cổng ML — né tránh, chế độ khó (bóp méo mọi đặc trưng; 13 ca bị lật, CI95 97,86–99,27)	1.036 ca tấn công đã bắt	1.023 → 98,75%
Cổng ML — chế độ một đặc trưng (∞ / cục đoạn)	1.036×2	100% cả hai
Cổng ML — từ chối phán quyết khi đầu vào biến dạng	4.236 sự kiện	116 → leo thang
<i>Tầng 2 — bảo chứng cấu trúc</i>		
Đóng gói dữ liệu phân định bằng nonce	678 mẫu khó, độ phủ 100%	678 → 100%
Tập theo vị trí trường, tách từng vị trí	100 mẫu công bố	24/24, 23/23, 30/30, 23/23
Kiểm lược đồ khi ép hỏng cỗ máy suy luận	1 lần ép hỏng	AWAIT_HITL, không sụp
Tắt định (cùng hạt giống, 5 lượt) / đổi riêng hạt giống	5 lượt / 10 mẫu	trùng khớp / 0 ca lật
Chống tràn ngữ cảnh	cửa sổ 16.384 token, ngân sách 4.000	xấu nhất 1.655
<i>Toàn vẹn pháp y</i>		
HMAC — ba kiểu giả mạo cốt lõi	30 lượt mỗi kiểu	100%
HMAC — đối chứng âm (chuỗi nguyên vẹn)	450 bản ghi	không báo động giả
HMAC — cắt đuôi chuỗi	—	0% — không phát hiện được

Lớp lọc tĩnh chặn được 18,8% các nguồn công bố, và con số đó phải đọc kèm tỉ lệ báo nhằm 20,0% trên nhật ký lảnh. Cả 46 lần báo nhằm đều xuất phát từ lớp phát hiện mã hoá, và cái giá của chúng có giới hạn: một cờ tĩnh chỉ nâng mức cô lập và chú thích bản ghi, chứ không loại sự kiện hay chặn nguồn, nên đó là tỉ lệ chú thích thừa chứ không phải tỉ lệ lưu lượng lảnh bị từ chối phục vụ. Tập tự soạn bị chặn ở mức 72,5% vì 45 trong 80 mẫu ấy là ca né tránh bằng mã hoá mà bộ vô hiệu hoá sinh ra đúng để trị; báo con số gộp 23,3% sẽ tăng bốc hệ thống bằng cách đếm cả những mẫu viết ra khi đã biết cơ chế phòng thủ, nên

18,8% mới là con số luận văn đứng sau.



Hình 8. Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhầm trên log lạnh. Sinh từ `robustness_results.json` và `adversarial_negative_results.json`. (Nguồn: Tác giả)

Ở chế độ khó, nơi *toàn bộ* đặc trưng của một ca tấn công đã bị bắt đúng bị đẩy tới cực trị, 98,75% số mẫu vẫn kháng được. Hai chế độ một-đặc-trung đạt 100%, và luận văn trích chế độ khó chứ không trích trung bình ba chế độ, vì gộp thêm hai chế độ bảo hoà tầm thường sẽ thổi con số vượt quá mức phòng tuyến thực sự chứng minh được. Việc từ chối phán quyết được tính là kết quả của rào chắn: 116 sự kiện được đẩy lên thay vì đoán bừa.

Bảo chứng an ninh đến từ Đóng gói Dữ liệu Phân định, đánh giá ở độ phủ 100% trên toàn bộ 678 mẫu thuộc bảy nhóm mà lớp tĩnh không hấp thụ được—tập cha của 543 mẫu thật sự lọt qua, nên phép thử chặt hơn mức cần thiết chứ không phải được lấy mẫu thiên vị. Tầng 2 kháng được 678 trên 678. Đó là khác biệt về bản chất: một bộ phân loại chặn $x\%$ thì luôn để lọt phần còn lại và suy giảm trước biến thể mới, còn một bảo chứng cấu trúc thì hoàn toàn không phụ thuộc vào việc nhận dạng nội dung độc hại, nên con số 18,8% không mâu thuẫn với luận văn mà định lượng khối việc lớp cấu trúc phải gánh. Vị trí trường được đo tách riêng, vì cơ chế bọc theo từng trường và không con số gộp nào kiểm được: trên 100 mẫu rải qua URI, User-Agent, message và payload, lớp tĩnh chặn 12 còn Tầng 2 kháng cả 100, đồng đều ở cả bốn vị trí. Hai phép kiểm ổn định chống đỡ cho các phép đo phụ thuộc mô hình, mỗi phép kèm giới hạn: hạt giống cố định cho hành động trùng khớp qua năm

lượt nhưng chỉ trên một mẫu, còn đổi riêng hạt giống trên mười mẫu không làm lật phán quyết nào—ở $n = 10$ điều đó chỉ chặn tỉ lệ lật ở mức 0,2775 và bảo hoà trên một hành động duy nhất.

Việc kiểm chứng tính lại toàn bộ chuỗi từ bản ghi khởi thủy; vì mỗi mắt xích tiêu thụ hash của mắt xích trước, một byte bị sửa trong D_j làm hỏng mọi mắt xích từ j trở đi, nên phát hiện có định vị chứ không chỉ là báo rằng có gì đó đã đổi. Ba kiểu giả mạo cốt lõi—sửa nội dung, chèn bản ghi giả, xoá bản ghi giữa chuỗi—đều bị phát hiện trong 30 trên 30 lượt thử, và đối chứng âm trên 450 bản ghi nguyên vẹn không sinh báo động giả nào. Phép đo chạy với khoá nạp từ môi trường chứ không phải khoá mặc định trong mã, bởi một khoá lộ trong mã nguồn cho phép giả mạo lại cả chuỗi và làm vô hiệu mọi tỉ lệ ở trên. Cắt đuôi chuỗi thì không phát hiện được—thuộc tính cố hữu của kỹ thuật nối chuỗi nhật ký—và cách khắc phục là neo định kỳ giá trị băm ra ngoài hệ thống.

Một phép đo đã phải chạy lại, và lý do thì khái quát được. Kết quả theo từng vị trí ban đầu chỉ dựa trên 79 phán quyết độc lập chứ không phải 100, vì khoá cache lớp hai bỏ sót `user_agent` và gộp 23 mẫu User-Agent về hai dấu vân: hai phán quyết phát lại hai mươi một lần, đúng ở cột mà thí nghiệm sinh ra để kiểm. Một khiếm khuyết của dụng cụ đo và một mặt tấn công đầu độc cache đang sống ở đây là cùng một khiếm khuyết, bởi kẻ tấn công trong vận hành cũng có thể đổi riêng một trường vắng mặt trong khoá và nhận lại phán quyết đã lưu. Mở rộng khoá đưa số dấu vân về đúng 100; kết quả sau khi sửa trùng khít con số trước khi sửa, và đó chính là lý do mẫu số phải được kiểm chứ không được mặc định là đúng.

4.4 RQ3 — Suy luận Có trạng thái và Quy kết Kỹ thuật

Bốn vế của RQ3—quy kết, truy xuất, báo cáo minh bạch và giảm tải người—được đo riêng, vì chúng hỏng vì những lý do khác nhau.

Thêm tầng suy luận thì quy kết xấu đi. Trên cùng một dân số 500 mẫu tầng payload (250 mẫu có nhãn, 250 mẫu lành, nguồn CSIC 2010), chỉ riêng truy xuất đã quy kết đúng 80,0%, trong khi toàn tuyến tác tử tụt xuống 68,0%, và mức chiến thuật từ 80,0% xuống 70,4%,

với độ trễ trung vị tăng từ 0,54 ms lên 13.293 ms. Tăng suy luận tiêu tốn thêm bốn bậc độ lớn về thời gian và trả lại độ chính xác thấp hơn mười hai điểm so với chính tầng nó được thêm vào để cải thiện. Trong 30 mẫu mất, tối đa 22 mẫu là những ca rào chắn neo ép về N/A vì mã kỹ thuật đề xuất không hiện diện trong tài liệu truy xuất của chính lô đó—một đánh đổi có chủ ý giữa độ chính xác và bảo chứng rằng hệ không bao giờ hành động dựa trên một mã không có bằng chứng đỡ. Mọi con số ở đây đọc so với một cái sàn chứ không so với 0: T1595.003 chiếm 130 trong 250 mẫu có nhãn, nên luôn trả lời mã đó đã đạt 52%.

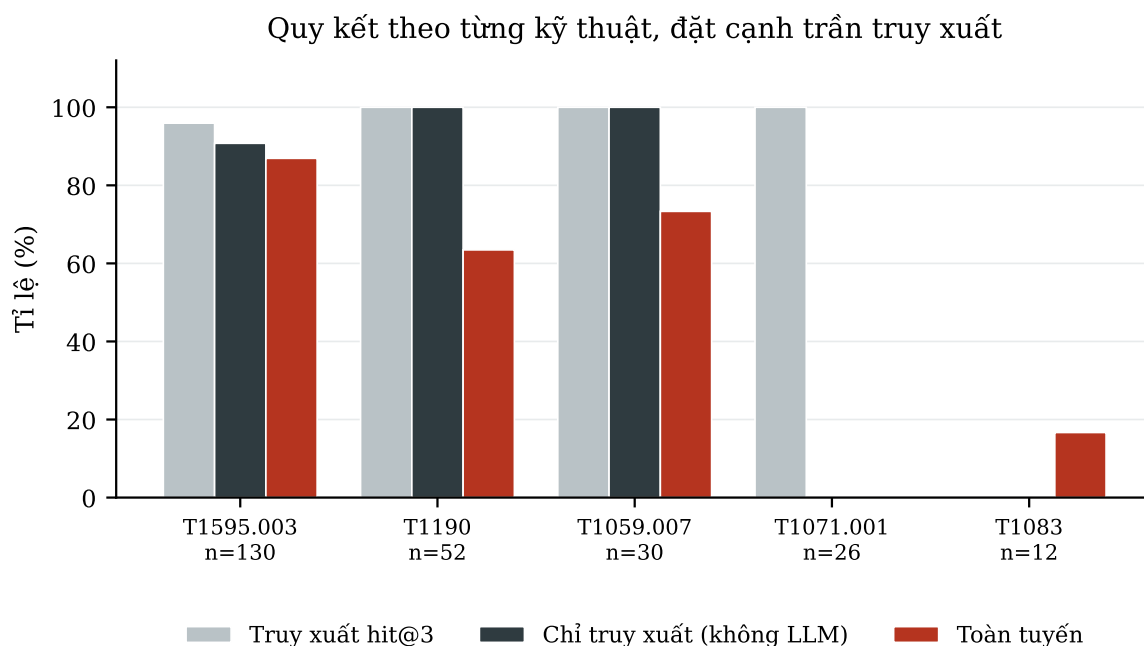
Bảng 6. Quy kết theo từng kỹ thuật trên lát 500 mẫu tầng payload, kèm trần truy xuất của cùng bộ truy vấn. Quy kết chấm trên cả 250 mẫu có nhãn; truy xuất chấm trên 243 mẫu mà Tầng 1 có leo thang, và ở mức kỹ thuật cha—hai mẫu số vì vậy lệch nhau và không thay thế cho nhau được.

Kỹ thuật ATT&CK	<i>n</i>	Truy xuất hit@3	Chỉ truy xuất	Toàn tuyến
T1190 — Khai thác ứng dụng công khai	52	1,00	100,0%	63,5%
T1059.007 — Thực thi JavaScript	30	1,00	100,0%	73,3%
T1595.003 — Quét theo từ điển	130	0,96	90,8%	86,9%
T1083 — Dò tệp và thư mục	12	0,00	0,0%	16,7%
T1071.001 — Giao thức web	26	1,00	0,0%	0,0%
Toàn bộ kỹ thuật	250	0,93	80,0%	68,0%

Bảng 6 làm được điều con số gộp không làm được: nó định vị tầng nào hỏng. Với T1083, bộ truy xuất không bao giờ trả về đúng tài liệu, nên lỗi nằm ở kho tri thức và không thành phần nào phía sau cứu được; với T1071.001, bộ truy xuất trả đúng ở mọi lượt mà quy kết vẫn bằng không, nên lỗi nằm ở bộ ánh xạ. Hai lỗi cần hai cách sửa khác nhau, và một con số 68,0% đứng một mình thì không kê được toa nào.

Trên cùng lát 243 truy vấn đã leo thang, Dual-RAG đạt Recall@3 = 0,930 (KTC 95% 0,891–0,956) và MRR 0,803, nằm thoải mái phía trên các con số quy kết nên mạch lập luận khép kín: truy xuất không phải thứ chặn mức 80,0%. Nửa bất lợi phải nêu rõ ràng không kém. Đo trên toàn bộ tập ground_truth gồm 1.305 truy vấn, Recall@3 sụp còn 0,385, vì các mẫu chỉ có tầng luồng chi phối dân số đó và không mang chữ tầng ứng dụng nào để khớp—T1110 đạt hit@3 0,00 trên 236 truy vấn. Hai con số mô tả hai dân số khác nhau, và đem 0,385 đặt cạnh 80,0% là vi phạm chính nguyên tắc ở Mục 4.1.

Nếu chỉ đọc phán quyết cuối thì *bất kỳ* lá chắn nào cũng đạt không ảo giác, kể cả một lá



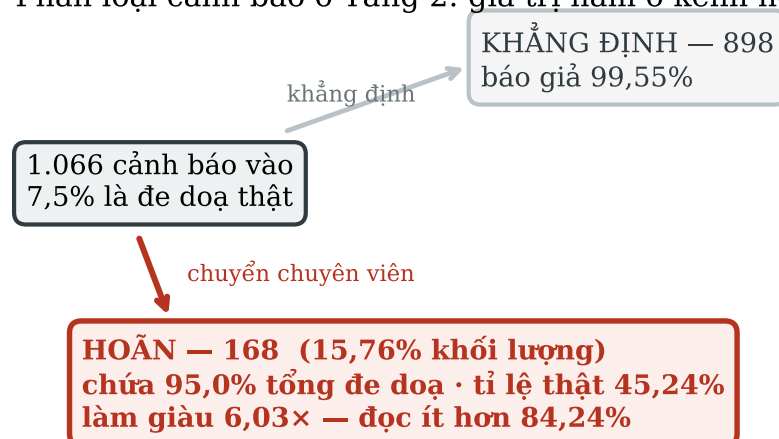
Hình 9. Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhạt cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhạt bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)

chấn chẳng làm gì, nên phép đo chạy trên bản ghi thực thi có lưu hành động trước và sau lá chắn: trong 1.566 lô, có 1.421 lô khẳng định một kỹ thuật, và không một khẳng định nào trong 1.421 lô đó thiếu neo—vẫn bằng không kể cả khi nói tới kỹ thuật cha. Lá chắn không hề nằm im khi đạt kết quả ấy: nó kích hoạt trên 9,26% số lô và ở 76 lô đã hạ BLOCK_IP xuống AWAIT_HITL, ngăn 76 lệnh chặn IP vĩnh viễn tự động mà lời biện giải không neo được vào bằng chứng. Một giới hạn nêu chủ động: điểm số dùng thước chặt, mã phải nằm trong danh sách ID tài liệu đã truy xuất, trong khi lá chắn đang vận hành khớp bằng biểu thức chính quy trên toàn văn ngữ cảnh, nên số không ở đây là cận trên của số ca bỏ lọt chứ không phải con số chính xác.

Tầng 1 đẩy lên 1.066 cảnh báo, trong đó chỉ 80 ca (7,5%) là đe dọa thật. Xét như một bộ phân loại nhị phân trên hàng đợi đó, mô hình vô giá trị: nó gấn cờ cả 1.066 ca, không hạ cấp ca nào trong 986 cảnh báo giả, nên đạt MCC 0,0 và Balanced Accuracy 0,5, với tỉ lệ báo giả 99,55% trong phần nó chủ động khẳng định. Độ tự tin của nó gây lạc hướng chứ không chỉ vô nghĩa—tự tin trung bình 0,846 trong khi tỉ lệ thật là 7,5%, sai số hiệu chuẩn kỳ vọng 0,803, và 900 phán quyết tự tin nhất thì đúng không lần nào.

Giá trị nằm ở đúng cái kênh mà cách đóng khung nhị phân bỏ qua. Tác tử hoãn 168 cảnh báo, tức 15,76% lượng đầu vào, và hàng đợi đó chứa 76 trong 80 đe dọa thật (95,0%) với mật độ cảnh báo thật 45,24% so với 7,5% ở đầu vào: mức làm giàu $6,03\times$, nên chuyên viên chỉ xem hàng đợi hoãn sẽ đọc ít hơn 84,24% khối lượng mà vẫn thấy 95,0% đe dọa thật. Kết luận là một phát hiện chứ không phải lời biện hộ: mô hình này dùng được như bộ định tuyến phân loại và không dùng được như bộ tự khẳng định. MCC 0,0 không mâu thuẫn với RQ3, vốn hỏi về việc giảm và *phân loại chính xác* phần việc cần người; và vì 910 trong 1.066 ca leo thang là lưu lượng CSIC lành, con số này còn phản ánh chất lượng quyết định leo thang của Tầng 1 chứ không riêng của tác tử.

Phân loại cảnh báo ở Tầng 2: giá trị nằm ở kênh hoãn, không ở phán quyết



Hình 10. Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ `tier2_decision_results.json`. (Nguồn: Tác giả)

Một trọng tài khác họ mô hình (Meta-Llama-3-8B-Instruct chấm Foundation-Sec-8B-Instruct) chấm toàn bộ 1.052 sự kiện leo thang trên bốn trục RAGAS [37], theo đúng khuyến nghị nhằm loại bỏ Thiên kiến Tự đề cao [38]: độ chính xác ngữ cảnh 2,54; độ liên quan câu trả lời 4,52; độ trung thành 3,96; độ bao phủ ngữ cảnh 4,11; trung bình 3,78/5,0. Hai kết quả bất lợi cho hệ. Độ chính xác ngữ cảnh 2,54 là trục yếu nhất và củng cố chẩn đoán về truy xuất, vì tập tài liệu trả về thường mang theo những mục không liên quan tới sự kiện đang xét. Nghiêm trọng hơn, chỉ số neo bằng chứng chỉ đạt 11,2% (KTC 95% 9,5–13,3): khoảng chín trên mười lời biện giải không dẫn ra một giá trị log nào đối chiếu ngược lại bản ghi được. Đây là khoảng cách rõ nét nhất giữa cái kiến trúc *bảo chứng* và cái nó *tự nguyện đưa ra*—rào chắn neo chứng minh được mã đã khẳng định có tài liệu đỡ lưng,

nhưng không có gì buộc phần văn xuôi xung quanh phải trích những giá trị trường đã dẫn tới đó—nên về báo cáo pháp y minh bạch mới đạt một phần, và bịt nó là việc ràng buộc định dạng biện giải chứ không phải cải thiện mô hình.

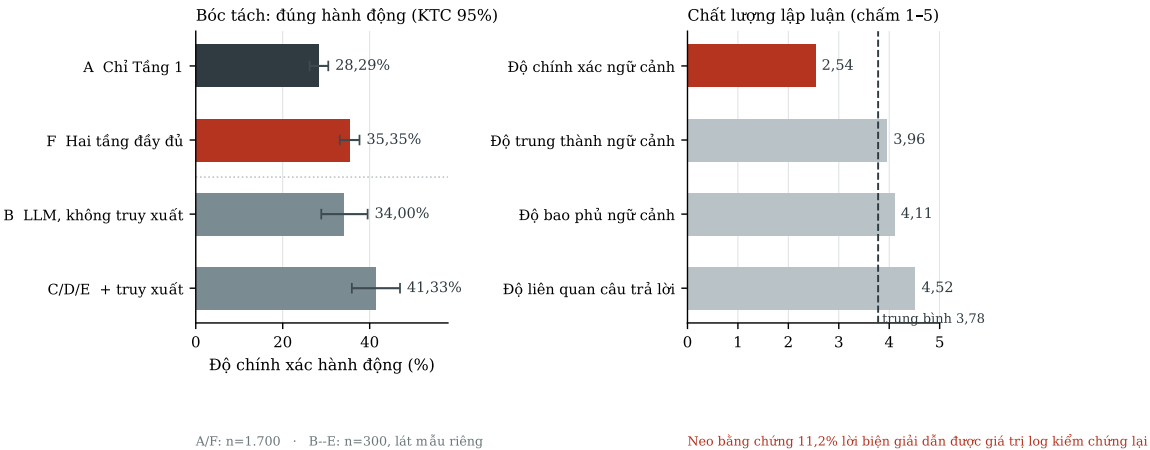
Ở phép bóc tách thành phần, cách chấm nhị phân không dùng được: tỉ lệ tấn công 86,9% khiến mọi cấu hình cho điểm sát con số đó và phép so súp đổ, đó là lý do trước đây mọi cấu hình trông y hệt nhau. Chấm theo hành động cuối—phán quyết phát ra có khớp phán quyết kỳ vọng hay không, trên bốn giá trị BLOCK_IP, ALERT, LOG và AWAIT_HITL—khôi phục lại khả năng phân biệt. Việc đổi thước được nêu ra thay vì lặng lẽ bỏ qua, vì một thước chọn sau khi đã thấy kết quả là thước đáng ngờ; căn cứ ở đây là thước nhị phân suy biến trên phân bố này, không phải vì nó cho con số khó coi.

Bảng 7. Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên không so trực tiếp với A và F được. Sinh từ `ablation_action_scores.json`.

Cấu hình	<i>n</i>	Đúng h.động (KTC 95%)	Tự quyết	Hoãn	C.xác tự quyết
A — Chỉ Tầng 1, không LLM	1.700	28,29% (26,20–30,48)	41,00%	0,00%	69,01%
F — Hệ hai tầng đầy đủ	1.700	35,35% (33,12–37,66)	55,24%	44,76%	57,72%
B — LLM, không truy xuất	300	34,00% (28,87–39,53)	69,67%	30,33%	45,93%
C — + truy xuất dày	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
D — + truy xuất thưa	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
E — + hợp nhất hạng	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%

Ba phát hiện rút ra, và cái thứ hai đáng kể nhất. Tầng suy luận xứng đáng với chi phí của nó, 35,35% so với 28,29%, hai khoảng tin cậy không chồng lấn. Nhưng sự đánh đổi đảo chiều: riêng Tầng 1 lại là bên phán quyết đáng tin hơn mỗi khi nó chịu quyết, 69,01% so với 57,72%, mà nó chỉ chịu quyết trên 41,00% số sự kiện và bỏ ngỏ 59,00%, đẩy chúng lên một tầng mà ở cấu hình A vốn không tồn tại. Hệ đầy đủ không bỏ ngỏ ca nào, chuyển toàn bộ phần tồn đọng thành 44,76% ca hoãn tường minh. Hai tầng khác nhau không nhiều ở chỗ suy nghĩ giỏi đến đâu, mà ở cách hành xử khi không biết—đúng thuộc tính mà kênh hoãn đã đo từ chiều ngược lại. Thứ ba, một kết quả rỗng: C, D và E trùng khít tới từng chữ số, nên thêm truy xuất thưa vào truy xuất dày rồi hợp nhất hai bảng hạng không làm đổi một phán quyết nào trên lát này. Đó là giới hạn của thiết kế bóc tách chứ không phải bằng chứng rằng bậc thang truy xuất vô dụng, vì cả ba cấu hình chỉ gọi mô hình với sự kiện đã

leo thang còn phần còn lại rơi về cùng một tier1_verdict. Muốn cô lập đóng góp của phép hợp nhất hạng thì phải đánh giá riêng trên các sự kiện đã leo thang—đúng thứ phép đo truy xuất ở trên cung cấp còn phép bóc tách này thì không.



Hình 11. Trái: độ chính xác hành động theo cấu hình kèm khoảng tin cậy 95%; A và F chung mẫu số, B–E thì không. Phải: bốn trục trọng tài chấm, với độ chính xác ngữ cảnh là trục yếu. Sinh từ ablation_action_scores.json và reasoning_eval_results.json. (Nguồn: Tác giả)

Khả năng tương quan có trạng thái dựng lại được cả 3/3 chuỗi đa ngày thật của DAPT2020 mà không sinh cảnh báo chiến dịch giả nào trên 4 chuỗi lành, nhưng ba ca dương đặt khoảng tin cậy 95% của độ bao phủ vào giữa 0,44 và 1,00, tương thích với cả một hệ chạy đúng lần một hệ gặp may, nên tương quan đa giai đoạn vẫn ở mức minh chứng khả thi. Cuối cùng, một kết quả tưởng như tiêu cực lại xác nhận thiết kế: trên nhóm mẫu ngoài NetFlow, Cổng ML chỉ đạt Recall 11,1% và 305 trong 336 ca trượt của toàn tập nằm gọn trong nhóm này, bởi Cổng học trên đặc trưng luồng còn tấn công web nằm ở payload—phần việc của Tầng 2 và tập chữ ký. Recall tổng 0,755 vì thế đang trộn hai quần thể không cộng được và phải bóc tách bạch. Liên quan tới điều đó, như đã nêu ở Mục 3.4, tỉ lệ chuyển chuyên gia không phải chỉ số cần tối thiểu hoá: một kiến trúc tuyên bố tỉ lệ chuyển-người bằng 0 trên mọi tình huống là kiến trúc đã bỏ mất rào chắn cuối cùng.

Chương 5

Kết luận

Một Trung tâm Điều hành An ninh hiểm khi thất bại vì một cuộc xâm nhập không bị phát hiện. Nó thất bại ở bước sau phát hiện, nơi một số hữu hạn chuyên viên phải quyết định trong dòng cảnh báo gần như vô hạn thì cái nào đáng được chú ý. Mô hình ngôn ngữ là công nghệ đầu tiên đọc được một sự kiện trong ngữ cảnh của nó và diễn giải bằng thứ ngôn ngữ con người hành động được, nhưng đặt nó vào luồng vận hành lại phát sinh những khoản chi phí về thời gian, về niềm tin và về chủ quyền dữ liệu mà không con số độ chính xác đầu bảng nào giải quyết. Luận văn đặt câu hỏi liệu có thể có được năng lực ấy mà không phải trả đủ cái giá của nó, và trả lời bằng cách xây dựng SENTINEL—một kiến trúc hai tầng giải quyết phán quyết rẽ trước phán quyết đất, triển khai hoàn toàn trên một máy trạm cục bộ—rồi đo nó thay vì mô tả nó. Ba kết quả đồ lấy tuyên bố đó.

Kinh tế học phân tầng đứng vững, và đứng vững như một quy luật chứ không phải một con số. Tầng 1 cùng Cổng Học máy giải quyết 90,6% một luồng chuẩn mang tỉ lệ tấn công cao hơn ba lần mức thực tế, và 97,5% một luồng ở tỉ lệ nền gần thực tế, cả hai đều không tốn một lời gọi mô hình ngôn ngữ nào. Vì sự kiện điển hình không bao giờ chạm tới mô hình, độ trễ toàn tuyến ở mức trung vị giảm còn 0,88 ms so với 17.174,7 ms của đường đơn tầng. Kết quả phương pháp luận còn đáng giá hơn cả hai con số: tỉ lệ gỡ tải phân tách tuyến tính thành tỉ lệ trên ca lãnh và tỉ lệ trên ca tấn công, tức nó là hàm của tỉ lệ tấn công nên trong luồng chứ không phải hằng số của hệ—đặc tính cho phép chuyển kết quả đo sang môi trường khác, điều mà một con số phần trăm đơn lẻ không làm được.

Bảo chứng an ninh mang tính cấu trúc, nên không suy giảm theo thời gian. Đóng gói Dữ liệu Phân định xử lý nội dung nằm trong ranh giới nonce theo lô như văn bản thụ động bất kể nội dung đó nói gì, và kháng được toàn bộ 678 mẫu đối kháng thuộc những nhóm mà

lớp lọc tĩnh rẻ tiền không hấp thụ nổi—đúng những nhóm mà lớp lọc ấy mù hoàn toàn. Đây là một loại bảo đảm khác hẳn với một bộ phân loại chặn được $x\%$ rồi để lọt phần còn lại trước mọi cách diễn đạt mới. Chuỗi HMAC-SHA256 phát hiện 100% cả ba kiểu giả mạo cốt lõi mà không báo động giả lần nào trên chuỗi đối chứng nguyên vẹn, niêm phong hồ sơ pháp y bằng tính toán vẹn và khả năng phát hiện giả mạo.

Kiểm soát hư cấu trở thành một ràng buộc kiểm chứng được thay vì một kỳ vọng. Mọi mã ATT&CK hệ phát ra đều phải hiện diện trong tài liệu truy xuất của chính lô đó; trên 1.421 phán quyết có khẳng định kỹ thuật, không một trường hợp nào thiếu neo. Số không ấy không phải điểm số tầm thường của một lá chắn không bao giờ ra tay: nó can thiệp trên 9,26% số lô, và 76 lần can thiệp trong đó đã giữ lại một lệnh chặn IP vĩnh viễn mà hệ thống không biện giải nổi bằng chứng cứ. Tầng suy luận cũng tỏ ra hữu ích nhất ở một vai trò khác với vai trò hiển nhiên—dùng làm bộ định tuyến phân loại thay vì bộ tự khẳng định, hàng đợi hoãn của nó gom 95,0% đe dọa thật vào 15,76% khối lượng, tức làm giàu $6,03\times$ và cắt đi 84,24% lượng tài liệu chuyên viên phải đọc.

Các giới hạn của kiến trúc được báo cáo đầy đủ ở nơi có bằng chứng của chúng, tại Chương 4, và ba trong số đó định ra chương trình làm việc trước mắt: quy kết hiện tốt hơn khi không có tầng suy luận, tác tử chưa tự bác bỏ được một cảnh báo giả, và tầng giải thích là mắt xích yếu nhất, bởi truy xuất còn để lọt tài liệu không liên quan và chỉ 11,2% lời biện giải dẫn ra một giá trị log đối chiếu ngược được với bản ghi. Các hướng tương ứng là sửa tầng truy xuất từ gốc kho tri thức, hiệu chuẩn tác tử cho cả việc bác bỏ chứ không chỉ việc khẳng định, và một định dạng biện giải buộc phải trích dẫn thay vì chỉ cho phép trích dẫn. Hai mở rộng nhỏ hơn suy ra từ những tính chất đã nêu: neo định kỳ giá trị băm ra ngoài hệ thống sẽ bịt điểm mù cắt đuôi vốn có của chuỗi nhật ký, và chữ ký bất đối xứng sẽ nâng khả năng phát hiện giả mạo lên thành chống chối bỏ thực sự.

Khép lại một nỗ lực nghiên cứu nghiêm túc, nhưng mở ra những khát vọng sâu xa trong hành trình bảo vệ không gian số bằng sức mạnh của Trí tuệ Nhân tạo Tác tử.

Tài liệu tham khảo

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] B. A. AlAhmadi, L. Axon, and I. Martinovic, “99% False Positives: A Qualitative Study of SOC Analysts’ Perspectives on Security Alarms,” in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [4] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [5] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [6] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [8] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [9] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [10] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Marañón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [11] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [12] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [13] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [14] jackhhao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023.

- [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [15] R. Zuech, T. M. Khoshgoftaar, and R. Wald, "Intrusion Detection and Big Heterogeneous Data: A Survey," *Journal of Big Data*, vol. 2, art. 3, 2015.
 - [16] B. P. Welford, "Note on a Method for Calculating Corrected Sums of Squares and Products," *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
 - [17] A. Gholami *et al.*, "A Survey of Quantization Methods for Efficient Neural Network Inference," *arXiv preprint arXiv:2103.13630*, 2021.
 - [18] S. Weerawardhena, P. Kassianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report," *arXiv preprint arXiv:2508.01059*, 2025.
 - [19] P. Kassianik, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report," *arXiv preprint arXiv:2504.21039*, 2025.
 - [20] LangChain AI, "LangGraph: Multi-Actor, Stateful LLM Applications," *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
 - [21] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
 - [22] J. Johnson, M. Douze, and H. Jégou, "Billion-Scale Similarity Search with GPUs," *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
 - [23] S. Robertson and H. Zaragoza, "The Probabilistic Relevance Framework: BM25 and Beyond," *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
 - [24] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods," in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
 - [25] R. Pandey and A. Bhujang, "Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content," *arXiv preprint arXiv:2605.24421*, 2026.
 - [26] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-Hashing for Message Authentication," Internet Engineering Task Force, RFC 2104, 1997.
 - [27] J. Zhang *et al.*, "When LLMs Meet Cybersecurity: A Systematic Literature Review," *Cybersecurity*, vol. 8, 2025.
 - [28] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An Agentic RAG cyber attack classification and reporting tool," *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
 - [29] Z. Liu and A. Anwar, "AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation," *arXiv preprint arXiv:2508.13118*, 2025.
 - [30] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, "LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations," *arXiv preprint arXiv:2604.05440*, 2026.
 - [31] R. Sahay *et al.*, "Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage," *arXiv preprint arXiv:2603.23966*, 2026.
 - [32] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, "Drain: An Online Log Parsing Approach with Fixed Depth Tree," in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
 - [33] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy," The MITRE Corporation,

Technical Report MP180360, 2018.

- [34] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [35] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [36] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
- [37] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [38] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.